ĐẠI HỌC KINH TẾ THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG CÔNG NGHỆ VÀ THIẾT KẾ
**KHOA CÔNG NGHỆ THÔNG TIN KINH DOANH**

# ĐỒ ÁN TỐT NGHIỆP

## SENTINELLAN: QUẢN LÝ VÀ GIÁM SÁT THIẾT BỊ ĐẦU CUỐI DOANH NGHIỆP

Giảng viên hướng dẫn: TS. Nguyễn An Tế
Sinh viên thực hiện: Lê Quang Khánh
MSSV: 31231025401
Ngành: Công nghệ thông tin

TP. Hồ Chí Minh, năm 2026

# LỜI CẢM ƠN

Tôi xin trân trọng cảm ơn TS. Nguyễn An Tế đã hướng dẫn tôi xác định bài toán, lựa chọn phạm vi và hoàn thiện đồ án SentinelLAN.

Tôi cảm ơn quý Thầy, Cô Khoa Công nghệ thông tin kinh doanh, Trường Công nghệ và Thiết kế, Đại học Kinh tế Thành phố Hồ Chí Minh đã trang bị kiến thức về phát triển phần mềm, mạng máy tính, cơ sở dữ liệu và an toàn thông tin để tôi vận dụng vào đồ án này.

# TÓM TẮT

SentinelLAN là hệ thống quản lý và giám sát thiết bị đầu cuối trong mạng nội bộ, kết hợp quy trình bàn giao máy, quan sát thông số kỹ thuật và hỗ trợ nhân viên. Đồ án xây dựng máy chủ backend bằng ASP.NET Core theo kiến trúc phân lớp, cơ sở dữ liệu PostgreSQL, cổng giao diện web dành cho quản trị viên (Admin) và nhân viên (Employee), ứng dụng di động bổ trợ cùng tiến trình Agent (.NET) chạy trên thiết bị. Trọng tâm của hệ thống là xác lập đúng danh tính máy, phân tách dữ liệu theo tổ chức, cập nhật telemetry định kỳ, kiểm soát quyền thao tác từ xa và theo dõi minh bạch kết quả xử lý.

Để bảo đảm an toàn giao tiếp, hệ thống tách biệt cơ chế xác thực hai chiều: mỗi Agent sử dụng khóa HMAC riêng để ký yêu cầu gửi lên máy chủ, trong khi các lệnh quản trị từ máy chủ được ký số bằng RSA-PSS. Vòng đời giao nhận lệnh được kiểm soát qua mã định danh, thời hạn hiệu lực, chỉ số chống phát lại (nonce), cơ chế giữ chỗ (lease) và biên lai xác nhận, đồng thời duy trì trạng thái chưa xác nhận khi thiếu bằng chứng thực thi do sự cố mạng

Quá trình đánh giá kết hợp kiểm thử tự động đa tầng và nghiệm thu theo tình huống nghiệp vụ. Đợt kiểm thử tự động ngày 23/10/2026 ghi nhận 380/382 ca kiểm thử .NET đạt yêu cầu (2 ca bỏ qua); các bộ kiểm thử Web UI, Mobile và trình duyệt (E2E) lần lượt đạt 127, 195 và 13 kịch bản, trong khi một số chỉ tiêu độ phủ mã nguồn của giao diện web và mobile còn dưới ngưỡng 80%. Thực nghiệm bổ sung trên thiết bị thực tế ngày 26/10/2026 đã xác nhận hoạt động xuyên suốt của luồng bàn giao thiết bị, gửi yêu cầu hỗ trợ kèm ảnh minh chứng có sự đồng ý của người dùng, tiếp nhận xử lý từ bộ phận IT, thu thập heartbeat và thực thi lệnh CollectTelemetryNow. Các kết quả này xác nhận tính đúng đắn của luồng giao tiếp Web–Agent–Máy chủ trong phạm vi thử nghiệm; việc nghiệm thu chuyên sâu trên thiết bị di động vật lý và các thao tác can thiệp hệ điều hành được định hướng cho giai đoạn phát triển tiếp theo

Từ khóa: quản lý thiết bị đầu cuối; Agent; giám sát kỹ thuật; hỗ trợ nhân viên; phân quyền theo tổ chức; nhật ký kiểm toán.

# MỤC LỤC

**CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI.....1**
1.1. Lý do chọn đề tài.....1
1.2. Mục tiêu nghiên cứu.....1
1.3. Câu hỏi nghiên cứu.....2
1.4. Đối tượng và phạm vi nghiên cứu.....2
1.5. Phương pháp nghiên cứu.....3
1.6. Ý nghĩa của đề tài.....4
1.7. Kết cấu đồ án.....4
1.8. Kế hoạch thực hiện.....4
**CHƯƠNG 2. CƠ SỞ LÝ LUẬN VÀ MÔ HÌNH HỆ THỐNG.....6**
2.1. Quản lý thiết bị và mô hình Agent–máy chủ.....6
2.2. Kiến trúc phân lớp.....6
2.3. Xác thực và phân quyền theo tài nguyên.....6
2.4. Bảo vệ thông điệp và dữ liệu.....7
2.5. Giao nhận lệnh và xử lý lặp.....7
2.6. Cơ sở dữ liệu và cập nhật giao diện.....8
2.7. Cơ sở đánh giá an toàn ứng dụng.....8
2.8. Giải pháp liên quan và mô hình áp dụng.....8
**CHƯƠNG 3. PHƯƠNG PHÁP NGHIÊN CỨU.....10**
3.1. Cách tiếp cận và quy trình thực hiện.....10
3.2. Nguồn dữ liệu và đơn vị quan sát.....10
3.3. Thiết kế tình huống kiểm thử.....11
3.4. Công cụ thu thập và phân tích.....12
3.5. Tiêu chí đánh giá và giới hạn suy luận.....12
3.6. Quy tắc sử dụng và trình bày nguồn.....13
**CHƯƠNG 4. KẾT QUẢ PHÂN TÍCH, THIẾT KẾ VÀ TRIỂN KHAI.....14**
4.1. Tác nhân và yêu cầu nghiệp vụ.....14
4.2. Quy trình bàn giao và hỗ trợ.....15
4.3. Kiến trúc và các thành phần triển khai.....18
4.4. Mô hình dữ liệu và tính nhất quán.....19

4.5. Thiết kế xác thực và bảo vệ dữ liệu.....21
4.5.1. Xác thực và phân quyền người dùng.....21
4.5.2. Xác thực thiết bị.....21
4.5.3. Bảo vệ dữ liệu và nhật ký.....22
4.6. Thiết kế giao lệnh và biên lai.....22
4.7. Agent Windows và các điều kiện thực thi.....24
4.8. Tài sản, chính sách và bảo trì.....25
4.9. Triển khai VPS và kiểm tra nguồn phiên bản.....25
4.10. Giao diện và nghiệm thu quy trình triển khai.....26
**CHƯƠNG 5. THẢO LUẬN KẾT QUẢ VÀ GIẢI PHÁP HOÀN THIỆN.....37**
5.1. Kết quả kiểm thử tự động.....37
5.2. Phép đo cục bộ và phục hồi HTTP.....38
5.3. Kết quả nghiệm thu web trên bản triển khai.....39
5.4. Thảo luận theo mục tiêu và câu hỏi nghiên cứu.....40
5.5. Các điểm giao diện cần cải thiện.....41
5.6. Giải pháp hoàn thiện vận hành.....42
**CHƯƠNG 6. KẾT LUẬN, HẠN CHẾ VÀ HƯỚNG PHÁT TRIỂN.....43**
6.1. Kết luận.....43
6.2. Hạn chế.....43
6.3. Hướng phát triển.....44
**TÀI LIỆU THAM KHẢO.....4**

# DANH MỤC BẢNG

Bảng 1.1: Mục tiêu, đầu ra và tiêu chí đánh giá.....2
Bảng 1.2: Giới hạn dữ liệu và chức năng.....3
Bảng 1.3: Kế hoạch thực hiện theo tuần.....4
Bảng 2.1: Đối chiếu phạm vi chức năng từ tài liệu chính thức.....9
Bảng 3.1: Nguồn dữ liệu và công dụng trong đánh giá.....11
Bảng 3.2: Tình huống nghiệm thu trên bản triển khai.....11
Bảng 4.1: Tác nhân và phạm vi trách nhiệm.....14
Bảng 4.2: Yêu cầu chức năng.....14
Bảng 4.3: Điểm kiểm soát trong luồng hỗ trợ.....17
Bảng 4.4: Nhóm dữ liệu và ràng buộc chính.....20
Bảng 5.1: Kết quả kiểm thử theo hồ sơ ngày 23/10/2026.....37
Bảng 5.2: Độ phủ mã nguồn theo bộ đo.....37
Bảng 5.3: Kết quả phép đo cục bộ đã lưu.....38
Bảng 5.4: Đối chiếu tình huống nghiệm thu và bằng chứng.....39
Bảng 5.5: Mức đáp ứng mục tiêu của đồ án.....41
Bảng 5.6: Vấn đề quan sát được và giải pháp đề xuất.....41

# DANH MỤC HÌNH

Hình 4.1: Trình tự đăng ký và bàn giao thiết bị.....16
Hình 4.2: Thành phần hệ thống và hướng giao tiếp.....18
Hình 4.3: Mô hình quan hệ nghiệp vụ chọn lọc.....19
Hình 4.4: Vòng đời giao lệnh và nhận kết quả.....23
Hình 4.5: Image API trên VPS mang commit af4fb1d.....26
Hình 4.6: Tổng quan quản trị trên hệ thống đã triển khai.....27
Hình 4.7: Admin tìm thiết bị SWEETYCANDY trước bàn giao.....27
Hình 4.8: SWEETYCANDY Online và đã có người sử dụng.....28
Hình 4.9: Employee xem máy được bàn giao và heartbeat mới.....29
Hình 4.10: Employee mô tả yêu cầu hỗ trợ nghiệm thu.....30
Hình 4.11: Xem trước ảnh và yêu cầu đồng ý trước khi gửi.....31
Hình 4.12: Ảnh đính kèm hiển thị trong cổng Admin.....32
Hình 4.13: IT tiếp nhận và phân công yêu cầu hỗ trợ.....33
Hình 4.14: Employee theo dõi trạng thái IT đang xử lý.....34
Hình 4.15: Lệnh CollectTelemetryNow có trạng thái thành công.....34
Hình 4.16: Chi tiết biên lai Agent và kết quả cập nhật thông số.....35
Hình 4.17: Audit ghi nhận hoạt động bàn giao, hỗ trợ và lệnh.....35
Hình 4.18: Cảnh báo thiết bị cần IT kiểm tra.....36

# DANH MỤC TỪ VIẾT TẮT

| Từ viết tắt | Diễn giải |
|---|---|
| API | Giao diện lập trình ứng dụng. |
| CPU | Bộ xử lý trung tâm. |
| CSRF | Giả mạo yêu cầu từ trang khác. |
| HMAC | Mã xác thực thông điệp sử dụng khóa bí mật. |
| IT | Công nghệ thông tin; trong nghiệp vụ là bộ phận hỗ trợ. |
| JWT | Token mang các khai báo định danh theo định dạng JSON Web Token. |
| OTP | Mã dùng một lần. |
| RAM | Bộ nhớ truy cập ngẫu nhiên. |
| RSA-PSS | Cơ chế chữ ký RSA với lược đồ đệm xác suất. |
| TLS | Giao thức bảo vệ dữ liệu khi truyền. |
| VPS | Máy chủ riêng ảo. |

# CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI

## 1.1. Lý do chọn đề tài

Quản lý máy tính trong tổ chức đòi hỏi xác định máy đang do ai sử dụng, tình trạng kỹ thuật gần nhất và công việc hỗ trợ đang được xử lý. Khi hồ sơ tài sản và yêu cầu hỗ trợ được theo dõi tách rời, người phụ trách phải đối chiếu lại thiết bị trước mỗi lần xử lý. Một yêu cầu thiếu thông tin máy hoặc trạng thái kết nối làm tăng số bước kiểm tra và dễ dẫn tới chọn sai đối tượng thao tác.

SentinelLAN giải quyết bài toán liên kết hồ sơ thiết bị, dữ liệu Agent và yêu cầu của nhân viên trên cùng hệ thống. Nhân viên được xem máy đã bàn giao và gửi mô tả vấn đề; Admin tiếp nhận yêu cầu trong đúng tổ chức, xem thông số máy và phát hành thao tác nằm trong danh sách cho phép. Mỗi bước thay đổi quan trọng được lưu nhật ký để đối chiếu người thực hiện và kết quả.

Các giải pháp GLPI, Wazuh, osquery và Endpoint Central đã cung cấp những nhóm chức năng quản lý hoặc quan sát thiết bị với phạm vi khác nhau. Đồ án lựa chọn một quy trình có thể triển khai và đánh giá trong điều kiện của sinh viên: từ đăng ký máy, bàn giao, cập nhật thông số đến hỗ trợ có lưu vết. Phần đối chiếu tính năng ở Chương 2 xác định phạm vi thiết kế, không đặt mục tiêu thay thế toàn bộ các sản phẩm này.

## 1.2. Mục tiêu nghiên cứu

Mục tiêu tổng quát là xây dựng và triển khai SentinelLAN để quản lý thiết bị đầu cuối và hỗ trợ nhân viên, bảo đảm người dùng thao tác đúng phạm vi quyền và kết quả xử lý có thể theo dõi trên hệ thống.

Các mục tiêu cụ thể được chuyển thành đầu ra và tiêu chí kiểm tra trong Bảng 1.1. Cách xác định này gắn mục tiêu của đồ án với chức năng có thể thực hiện trên sản phẩm.

Bảng 1.1: Mục tiêu, đầu ra và tiêu chí đánh giá

| Mục tiêu | Đầu ra cần đạt | Tiêu chí kiểm tra |
|---|---|---|
| Quản lý danh tính và bàn giao máy | Hồ sơ thiết bị gắn tổ chức và người sử dụng | Đăng ký có hạn; phân công đúng tổ chức; Employee chỉ xem máy được giao. |
| Giám sát kỹ thuật | Thông số và thời điểm kết nối từ Agent | Có heartbeat mới; dữ liệu có mốc thời gian; nhận lại mẫu không tạo trùng. |
| Hỗ trợ nhân viên | Yêu cầu gắn với máy và luồng IT tiếp nhận | Tạo yêu cầu, gửi ảnh có đồng ý, cập nhật người phụ trách và trạng thái. |
| Kiểm soát lệnh quản trị | Lệnh có lý do, chữ ký và kết quả | Xác minh máy đích, hạn và nonce; hiển thị biên lai thành công hoặc lỗi. |
| Triển khai và truy vết | Dịch vụ trên VPS, nhật ký và hồ sơ kiểm thử | API sẵn sàng; xác định commit triển khai; đối chiếu thao tác với audit. |

### 1.3. Câu hỏi nghiên cứu

Câu hỏi 1: Làm thế nào liên kết thiết bị, người được bàn giao và tổ chức để nhân viên truy cập đúng máy và gửi yêu cầu hỗ trợ đúng đối tượng?

Câu hỏi 2: Agent và máy chủ cần trao đổi danh tính, thông số và lệnh như thế nào để kiểm soát xác thực, phát lại và mất kết nối?

Câu hỏi 3: Quy trình hỗ trợ cần thể hiện những trạng thái nào để phân biệt yêu cầu đã tiếp nhận, lệnh đã giao và kết quả đã xác nhận?

Câu hỏi 4: Kết quả kiểm thử và nghiệm thu triển khai cho thấy hệ thống đã đáp ứng mục tiêu nào, còn hạn chế gì trước khi mở rộng sử dụng?

### 1.4. Đối tượng và phạm vi nghiên cứu

Đối tượng nghiên cứu là quy trình quản lý thiết bị đầu cuối có Agent và các cơ chế phần mềm phục vụ bàn giao máy, quan sát kỹ thuật, hỗ trợ nhân viên, xác thực và kiểm soát lệnh. Đơn vị đánh giá là hành vi của hệ thống trong từng tình huống nghiệp vụ và điều kiện vận hành được xác định trước.

Phạm vi không gian là môi trường triển khai thử của SentinelLAN trên VPS Oracle và thiết bị Windows được phép tham gia; cổng quản trị truy cập tại manager.zney295.id.vn. Dù thiết bị có thể nằm trong mạng nội bộ, Agent chủ động

kết nối ra máy chủ qua HTTPS. Các bên tham gia nghiệp vụ gồm hai vai trò đăng nhập Admin, Employee và chủ thể kỹ thuật Agent.

Phạm vi thời gian của kết quả được sử dụng là các hồ sơ kiểm thử ngày 23–24/10/2026 và phiên nghiệm thu web ngày 26/10/2026. Dữ liệu gồm mã nguồn, cấu hình mẫu, báo cáo kiểm thử, phép đo cục bộ đã lưu và ảnh cùng trạng thái thu từ hệ thống triển khai. Các dữ liệu này phục vụ đánh giá kỹ thuật của sản phẩm; đồ án không sử dụng bộ khảo sát nhân viên doanh nghiệp để suy rộng kết quả.

Bảng 1.2: Giới hạn dữ liệu và chức năng

| Nội dung | Phạm vi của đồ án |
|---|---|
| Dữ liệu quan sát | CPU, RAM, ổ hệ thống, thông tin phần cứng và trạng thái bảo vệ do Agent đọc được; có thời điểm thu thập. |
| Hỗ trợ | Nhân viên tạo yêu cầu trên máy được giao; tự chọn ảnh và xác nhận đồng ý gửi. |
| Tác động hệ điều hành | Mô tả triển khai và kiểm thử theo hồ sơ; phiên web chỉ thực hiện lệnh cập nhật thông số. |
| Mobile | Có mã nguồn và hồ sơ kiểm thử JavaScript; nghiệm thu thiết bị iOS, camera và push chưa được bổ sung. |
| Dữ liệu ngoài phạm vi | Nội dung cá nhân, ghi phím, thu ảnh bí mật và thực thi shell tùy ý. |

## 1.5. Phương pháp nghiên cứu

Đồ án thực hiện theo hướng thiết kế và phát triển hệ thống thông tin: xác định bài toán, đặt mục tiêu, xây dựng sản phẩm, trình diễn quy trình và đánh giá kết quả. Cách tổ chức này tham khảo phương pháp nghiên cứu khoa học thiết kế của Peffers và cộng sự (2007). Sản phẩm phần mềm và kết quả vận hành là đầu ra chính.

Phân tích định tính được dùng để mô hình hóa quy trình, quyền truy cập và nguyên nhân lỗi. Thống kê mô tả được dùng cho số ca kiểm thử, độ phủ mã nguồn và phép đo tài nguyên. Công cụ gồm bộ kiểm thử .NET, kiểm thử giao diện, trình duyệt tự động và Python để tổng hợp, đối chiếu hồ sơ. Chương 3 trình bày nguồn dữ liệu, cách chọn tình huống và tiêu chí đánh giá.

## 1.6. Ý nghĩa của đề tài

Về chuyên môn, đồ án vận dụng kiến thức phân tích hệ thống, cơ sở dữ liệu và an toàn ứng dụng vào một sản phẩm có giao tiếp giữa máy chủ và thiết bị. Đóng góp nằm ở cách phối hợp phân quyền theo tài nguyên với danh tính Agent, lệnh có chữ ký và kết quả được xác nhận bằng biên lai.

Về thực tiễn, SentinelLAN cung cấp một điểm theo dõi máy được giao, tình trạng kết nối và yêu cầu hỗ trợ. Người phụ trách IT có thể xem thông tin thiết bị ngay trong quy trình xử lý và đối chiếu lịch sử thao tác. Giá trị này được minh họa bằng phiên nghiệm thu; mức giảm thời gian hỗ trợ hoặc chi phí vận hành cần dữ liệu sử dụng tại tổ chức trước khi định lượng.

## 1.7. Kết cấu đồ án

Đồ án gồm sáu chương. Chương 1 giới thiệu bài toán, mục tiêu và phạm vi. Chương 2 trình bày cơ sở lý luận và mô hình hệ thống. Chương 3 xác định phương pháp thực hiện và đánh giá. Chương 4 trình bày kết quả phân tích, thiết kế và triển khai. Chương 5 thảo luận kết quả kiểm thử, nghiệm thu và giải pháp hoàn thiện. Chương 6 kết luận, nêu hạn chế và hướng phát triển. Danh mục tài liệu tham khảo đặt sau Chương 6.

## 1.8. Kế hoạch thực hiện

Kế hoạch ở Bảng 1.3 phân chia công việc theo tám tuần kể từ khi chốt đề cương. Đây là khung tiến độ dự kiến cho toàn bộ đồ án; các ngày kiểm thử và nghiệm thu thực tế được ghi riêng tại Chương 3 và Chương 5. Ngày nộp cuối cùng thực hiện theo lịch của học phần.

Bảng 1.3: Kế hoạch thực hiện theo tuần

| Thời gian | Công việc | Sản phẩm đầu ra |
|---|---|---|
| Tuần 1 | Chốt bài toán, mục tiêu, câu hỏi và phạm vi với giảng viên hướng dẫn | Đề cương và tiêu chí đánh giá. |
| Tuần 2 | Đọc tài liệu chính thức, xác định tác nhân và quy trình | Danh mục nguồn; yêu cầu và sơ đồ nghiệp vụ. |

| Thời gian | Công việc | Sản phẩm đầu ra |
|---|---|---|
| Tuần 3 | Thiết kế kiến trúc, dữ liệu và hợp đồng giao tiếp | Mô hình dữ liệu, API và quy tắc quyền. |
| Tuần 4–5 | Phát triển backend, web và Agent; tích hợp chức năng | Phiên bản chạy được và bộ kiểm thử. |
| Tuần 6 | Triển khai môi trường thử; thu kết quả kiểm thử và phép đo | Bản triển khai, log và dữ liệu đánh giá. |
| Tuần 7 | Nghiệm thu quy trình; chụp ảnh và viết bản thảo | Bằng chứng nghiệp vụ và bản thảo sáu chương. |
| Tuần 8 | Tiếp thu góp ý, kiểm tra nguồn, định dạng và nộp | DOCX, PDF và hồ sơ bằng chứng hoàn thiện. |

Nguồn: Tác giả đề xuất kế hoạch thực hiện đồ án.

# CHƯƠNG 2. CƠ SỞ LÝ LUẬN VÀ MÔ HÌNH HỆ THỐNG

## 2.1. Quản lý thiết bị và mô hình Agent–máy chủ

Quản lý thiết bị kết hợp thông tin tài sản với trạng thái kỹ thuật của máy. Hồ sơ tài sản cho biết thiết bị được mua, bàn giao và bảo trì như thế nào; dữ liệu kỹ thuật cho biết máy đã báo về điều gì ở một thời điểm cụ thể. Việc liên kết hai nhóm dữ liệu cho phép yêu cầu hỗ trợ tham chiếu đúng thiết bị và người sử dụng.

Trong mô hình được chọn, Agent chạy trên thiết bị và chủ động gửi dữ liệu tới máy chủ. Giao diện web đọc dữ liệu qua API, không mở kết nối trực tiếp tới từng máy. Mô hình phù hợp khi thiết bị nằm sau bộ định tuyến hoặc thay đổi mạng; độ mới của thông tin vẫn phụ thuộc vào chu kỳ gửi và đường truyền.

Mỗi mẫu cần có thời điểm thu thập và thời điểm máy chủ nhận. Trạng thái Online phản ánh heartbeat trong khoảng thời gian quy định; khi quá hạn, mẫu cuối được giữ như dữ liệu lịch sử. Dữ liệu do thiết bị tự báo còn chịu ảnh hưởng của quyền đọc và tình trạng hệ điều hành.

## 2.2. Kiến trúc phân lớp

Nguyên tắc phụ thuộc hướng vào nghiệp vụ giúp tách quy tắc xử lý khỏi cơ sở dữ liệu và giao diện. Martin (2017) trình bày cách tổ chức kiến trúc để chính sách nghiệp vụ ít phụ thuộc vào chi tiết kỹ thuật. SentinelLAN vận dụng nguyên tắc này qua các lớp Domain, Application, Infrastructure và Api.

Backend được triển khai như một ứng dụng có các module nghiệp vụ trong cùng tiến trình. Cách tổ chức này giảm số dịch vụ phải vận hành trong phạm vi đồ án và cho phép ghi thay đổi nghiệp vụ cùng sự kiện cần phát trong một giao dịch. Đổi lại, các module chia sẻ tài nguyên; khi cần tách thành dịch vụ độc lập, hợp đồng và cơ chế giao dịch phải được thiết kế lại.

## 2.3. Xác thực và phân quyền theo tài nguyên

NIST SP 800-207 đặt việc đánh giá quyền trên chủ thể và tài nguyên thay vì mặc nhiên tin cậy vị trí mạng (Rose và cộng sự, 2020). Trong SentinelLAN, nguyên

tắc này được áp dụng ở phạm vi ứng dụng: máy trong mạng nội bộ vẫn phải xác thực, còn tài khoản hợp lệ chỉ được truy cập dữ liệu thuộc phạm vi cho phép.

Kiểm tra vai trò xác định nhóm thao tác; kiểm tra tổ chức và quan hệ bàn giao xác định đối tượng được thao tác. Employee xem máy đang được giao cho mình, Admin quản lý tài nguyên trong tổ chức. Điều kiện này được thực hiện tại máy chủ để việc sửa URL hoặc gửi request ngoài giao diện vẫn chịu cùng kiểm soát.

### 2.4. Bảo vệ thông điệp và dữ liệu

HMAC kết hợp hàm băm và khóa bí mật để xác thực thông điệp (Krawczyk và cộng sự, 1997). Trong giao tiếp Agent, mỗi máy có khóa xác thực riêng; request được ràng buộc với nội dung và các thành phần giao tiếp. Nonce và kiểm tra thời gian bổ sung khả năng phát hiện gửi lại thông điệp đã dùng.

Chữ ký RSA-PSS được đặc tả trong RFC 8017 (Moriarty và cộng sự, 2016). Máy chủ giữ khóa riêng để ký lệnh; Agent chỉ cần khóa công khai để xác minh. Cách phân phối này tách quyền phát hành lệnh khỏi thiết bị nhận lệnh. TLS bảo vệ kênh truyền; chữ ký gắn nguồn phát và nội dung với từng lệnh.

PBKDF2 là cơ chế dẫn xuất khóa từ mật khẩu được mô tả trong RFC 8018 (Moriarty và cộng sự, 2017). AES-GCM cung cấp mã hóa kèm xác thực dữ liệu (Dworkin, 2007). Đồ án sử dụng hai cơ chế cho hai mục đích riêng: bảo vệ mật khẩu lưu trữ và bảo vệ nội dung hỗ trợ. Tham số triển khai được trình bày ở mục 4.5.

### 2.5. Giao nhận lệnh và xử lý lặp

Mất phản hồi HTTP tạo ra tình huống bên gửi chưa biết bên nhận đã ghi dữ liệu hay chưa. Khóa idempotency cho phép gửi lại một mẫu mà vẫn giữ một kết quả tương ứng trên máy chủ. Với lệnh quản trị, mã lệnh, nonce và biên lai giúp theo dõi giao nhận và tránh tự động thực hiện lại lệnh đã chấp nhận.

Lease là khoảng thời gian dành cho một lượt giao lệnh. Khi phản hồi bị mất, máy chủ có thể giao lại cùng lệnh sau khi lease hết hạn. Hạn bắt đầu thực thi và thời gian nhận biên lai được lưu riêng để chấp nhận kết quả đến muộn mà không mở

rộng quyền thực hiện. Nếu tiến trình dừng giữa bước ghi nonce và lưu biên lai, kết quả được giữ là chưa xác nhận để người vận hành kiểm tra.

### 2.6. Cơ sở dữ liệu và cập nhật giao diện

PostgreSQL hỗ trợ khóa chính, khóa ngoại, ràng buộc duy nhất và các điều kiện dữ liệu để duy trì tính nhất quán (PostgreSQL Global Development Group, n.d.). Trong thiết kế, ràng buộc duy nhất bổ sung cho kiểm tra nghiệp vụ, đặc biệt khi hai yêu cầu cùng tiêu thụ token hoặc gửi lại heartbeat.

SignalR hỗ trợ máy chủ đẩy thông báo tới client hoặc nhóm client, phù hợp với giao diện giám sát (Microsoft, 2026). SentinelLAN sử dụng thông báo để báo thay đổi và đánh thức vòng nhận lệnh của Agent. API vẫn là nơi đọc trạng thái nghiệp vụ và nhận lệnh đã ký; khi kết nối realtime được khôi phục, client tải lại dữ liệu hiện hành.

### 2.7. Cơ sở đánh giá an toàn ứng dụng

OWASP ASVS cung cấp tập yêu cầu cho thiết kế và xác minh an toàn ứng dụng, bao gồm xác thực, phân quyền và kiểm soát dữ liệu (OWASP Foundation, 2025). Đồ án tham khảo ASVS để lựa chọn nhóm tình huống kiểm tra có liên quan, tập trung vào truy cập sai tổ chức, sai máy được giao, token bị dùng lại và tải nội dung ảnh trái quyền.

Trong mô hình đánh giá, khả năng từ chối yêu cầu sai quyền quan trọng tương đương luồng hợp lệ. Điều kiện được kiểm tra ở endpoint, không dựa vào việc giao diện đã ẩn nút. Mức tuân thủ ASVS đầy đủ cần một ma trận yêu cầu riêng và đánh giá rộng hơn phạm vi kiểm thử của đồ án.

### 2.8. Giải pháp liên quan và mô hình áp dụng

Tài liệu GLPI mô tả quản lý tài sản và phiếu hỗ trợ; Wazuh sử dụng Agent cùng các thành phần máy chủ để giám sát an toàn; osquery biểu diễn thông tin hệ điều hành dưới dạng bảng có thể truy vấn; Endpoint Central tích hợp nhiều nghiệp vụ quản trị endpoint (Teclib, n.d.; Wazuh, n.d.; osquery, n.d.; ManageEngine, n.d.).

Bảng 2.1 đối chiếu định hướng chức năng được công bố để xác định phạm vi của SentinelLAN.

Bảng 2.1: Đối chiếu phạm vi chức năng từ tài liệu chính thức

| Giải pháp | Trọng tâm khảo sát | Liên hệ với đề tài |
|---|---|---|
| GLPI | Quản lý tài sản và helpdesk. | Tham chiếu cách liên kết tài sản với hỗ trợ; chưa benchmark. |
| Wazuh | Agent cùng server, indexer và dashboard cho giám sát an toàn. | Phạm vi phân tích sự kiện an toàn rộng hơn mục tiêu telemetry kỹ thuật của đề tài. |
| osquery | Biểu diễn trạng thái hệ điều hành để truy vấn bằng SQL. | Tham chiếu nhu cầu quan sát endpoint; không xem là hệ thống ticket tích hợp. |
| Endpoint Central | Quản trị endpoint, triển khai phần mềm và quản lý bản vá theo tài liệu nhà cung cấp. | Không đồng nhất danh sách cho phép lệnh của SentinelLAN với toàn bộ năng lực sản phẩm thương mại. |
| SentinelLAN | Vòng đời máy được ủy quyền, telemetry và self-service. | Đánh giá trong phạm vi triển khai và hồ sơ kiểm thử của đồ án. |

Nguồn: Tổng hợp từ Teclib (n.d.), Wazuh (n.d.), osquery (n.d.), ManageEngine (n.d.) và thiết kế SentinelLAN.

Mô hình áp dụng của đồ án liên kết bốn đối tượng nghiệp vụ: tổ chức, người dùng, thiết bị và yêu cầu hỗ trợ. Agent bổ sung dữ liệu kỹ thuật cho thiết bị; yêu cầu hỗ trợ tham chiếu thiết bị và người đang được bàn giao. Admin xử lý yêu cầu hoặc phát lệnh, Agent gửi kết quả, nhật ký lưu sự kiện. Chuỗi này là cơ sở thiết kế và xây dựng các tình huống đánh giá, thay cho mô hình kiểm định quan hệ giữa các biến khảo sát.

# CHƯƠNG 3. PHƯƠNG PHÁP NGHIÊN CỨU

## 3.1. Cách tiếp cận và quy trình thực hiện

Đồ án vận dụng nghiên cứu khoa học thiết kế theo định hướng tạo ra sản phẩm hệ thống thông tin. Peffers và cộng sự (2007) xác định tiến trình từ nhận diện vấn đề đến mục tiêu, thiết kế–phát triển, trình diễn, đánh giá và truyền đạt kết quả. Trong đồ án, tiến trình được cụ thể hóa thành yêu cầu nghiệp vụ, mô hình dữ liệu, mã nguồn, bản triển khai và các hồ sơ kiểm tra.

Yêu cầu được phân rã theo vòng đời của máy và công việc hỗ trợ. Mỗi chức năng có chủ thể, điều kiện đầu vào, thay đổi trạng thái và kết quả cần quan sát. Kiến trúc và hợp đồng API được thiết kế trước khi hoàn thiện các giao diện; kiểm thử được bổ sung tại lớp thực hiện quyết định nghiệp vụ và điểm giao tiếp liên quan.

Sau khi tích hợp, hệ thống được đánh giá bằng bộ kiểm thử tự động và tình huống chạy trên môi trường triển khai. Các lỗi quan sát được quay lại bước phân tích nguyên nhân và đề xuất điều chỉnh. Phần đánh giá tập trung trả lời bốn câu hỏi ở mục 1.3 bằng kết quả có thể đối chiếu.

## 3.2. Nguồn dữ liệu và đơn vị quan sát

Dữ liệu sơ cấp của đợt nghiệm thu ngày 26/10/2026 gồm trạng thái giao diện, phản hồi API, biên lai Agent, audit và ảnh chụp trong quá trình thao tác. Thiết bị được chọn là SWEETYCANDY đang có Agent kết nối. Hai tài khoản đại diện hai vai trò Admin và Employee được dùng ở các phiên trình duyệt riêng; đây là kiểm tra chức năng theo vai trò, không phải mẫu khảo sát người dùng.

Dữ liệu thứ cấp gồm tiêu chuẩn kỹ thuật, tài liệu nhà phát triển, mã nguồn và hồ sơ kiểm chứng ngày 23–24/10/2026 của dự án. Số ca kiểm thử tự động và phép đo cục bộ được tổng hợp từ hồ sơ kiểm chứng ngày 23–24/10/2026 tại mốc lưu hồ sơ 0c43c34; phiên nghiệm thu ngày 26/10/2026 bổ sung kiểm chứng trực tiếp trên môi trường triển khai af4fb1d. Thông tin về API đang triển khai được đối chiếu với commit máy chủ công bố để tách lịch sử kiểm thử khỏi phiên bản vận hành.

Bảng 3.1: Nguồn dữ liệu và công dụng trong đánh giá

| Nguồn | Mốc dữ liệu | Công dụng |
|---|---|---|
| Mã nguồn và hợp đồng | Kho SentinelLAN, mốc 0c43c34; bản API quan sát af4fb1d | Đối chiếu cơ chế, endpoint, tham số và cấu trúc dữ liệu. |
| Hồ sơ kiểm thử tự động | 23/10/2026, được tổng hợp trong hồ sơ 24/10 | Dẫn kết quả .NET, Web UI, Mobile, E2E và độ phủ. |
| Phép đo cục bộ đã lưu | 24/10/2026; Windows, HTTP loopback, InMemory | Đánh giá tài nguyên tiến trình và phục hồi HTTP trong điều kiện thử. |
| Nghiệm thu triển khai | 26/10/2026; web, Agent 1.0.4 và VPS | Kiểm tra bàn giao máy, hỗ trợ, telemetry, audit và phiên bản API. |
| Tài liệu bên ngoài | Nguồn chính thức, đối chiếu ngày 26/10/2026 | Căn cứ cho lựa chọn kiến trúc, mật mã và trình bày trích dẫn. |

### 3.3. Thiết kế tình huống kiểm thử

Tình huống được chọn theo rủi ro nghiệp vụ. Với danh tính máy, kiểm tra token hết hạn hoặc dùng lại; với bàn giao, kiểm tra cùng tổ chức và quyền truy cập sau đổi người sử dụng. Với hỗ trợ, kiểm tra nội dung yêu cầu, người phụ trách và quyền tải ảnh. Với lệnh, kiểm tra máy đích, chữ ký, nonce, thời hạn và kết quả trả về.

Kiểm thử đơn vị kiểm tra quy tắc riêng; kiểm thử tích hợp kiểm tra phối hợp thành phần theo provider được cấu hình; kiểm thử trình duyệt theo dõi luồng giao diện. Nghiệm thu web trên bản triển khai thực hiện chuỗi thao tác hợp lệ với thiết bị được phép. Các thao tác khóa, cô lập, gỡ Agent và thay đổi bảo vệ hệ điều hành không được dùng trong phiên chụp ảnh.

Bảng 3.2: Tình huống nghiệm thu trên bản triển khai

| Mã | Tình huống | Kết quả cần đối chiếu |
|---|---|---|
| NT01 | Đăng nhập hai vai trò và mở trang thiết bị | Admin xem máy trong tổ chức; Employee xem máy được giao. |
| NT02 | Chuyển bàn giao sang SWEETYCANDY | Lưu phân công, tải lại trang và kiểm tra ở cả hai vai trò. |
| NT03 | Tạo yêu cầu hỗ trợ có ảnh do Employee chọn | Có mã yêu cầu; xem trước, đồng ý gửi; Admin tải được ảnh đúng yêu cầu. |

| Mã | Tình huống | Kết quả cần đối chiếu |
|---|---|---|
| NT04 | IT tiếp nhận và phân công | Hai phía cùng thấy trạng thái InProgress và người phụ trách. |
| NT05 | Phát CollectTelemetryNow | Có mã lệnh, biên lai Succeeded và sự kiện hoàn thành. |
| NT06 | Quan sát heartbeat và VPS | Có hai mốc heartbeat mới; API ready; công bố commit và ảnh image API. |

### 3.4. Công cụ thu thập và phân tích

Hồ sơ tự động sử dụng kết quả TRX và các bản tổng kết kiểm thử giao diện. Python hỗ trợ đọc kết quả, lập bảng và kiểm tra tính nhất quán giữa số liệu với báo cáo. Thống kê mô tả gồm số lượng ca đạt, ca bỏ qua, tỷ lệ độ phủ và các giá trị tài nguyên đã thu. Không thực hiện kiểm định thống kê hay mô hình hồi quy vì tập dữ liệu phục vụ đánh giá phần mềm theo tình huống.

Phiên web sử dụng Chromium và Playwright để thao tác qua giao diện thật. Ảnh PNG gốc được giữ trong hồ sơ; hình chèn báo cáo trích vùng hiển thị để đọc rõ và giữ nguyên nội dung. Hồ sơ kèm URL nguồn, vai trò, thời điểm UTC và UTC+07, cùng SHA-256 trong manifest. JSON bằng chứng lưu các trạng thái quan trọng của yêu cầu, lệnh và heartbeat; không lưu mật khẩu, cookie hoặc token phiên trong gói bàn giao.

### 3.5. Tiêu chí đánh giá và giới hạn suy luận

Một tình huống được xác nhận theo đầu ra đã quy định. API tạo lệnh thành công chứng minh lệnh được ghi nhận; biên lai Succeeded xác nhận Agent báo hoàn tất công việc tương ứng. Thao tác có tác động lên hệ điều hành cần thêm quan sát tại máy. Trạng thái thiếu kết quả được giữ là chưa xác nhận thay vì tự chuyển thành hoàn thành.

Kết quả kiểm thử cũ, số đo cục bộ và nghiệm thu triển khai được đánh giá riêng. Phép thử HTTP/InMemory phản ánh điều kiện mô phỏng; luồng web trên PostgreSQL và HTTPS chứng minh nghiệp vụ đã thực hiện trong phiên đó. Đánh giá tải, khôi phục bản sao lưu, mất mạng vật lý và độ ổn định dài hạn cần các thí nghiệm bổ sung.

### 3.6. Quy tắc sử dụng và trình bày nguồn

Báo cáo sử dụng trích dẫn tác giả–năm theo hướng dẫn Harvard do UEH công bố. Các ý tham khảo được diễn giải bằng lời của tác giả; tài liệu không có năm công bố xác minh được dùng ký hiệu n.d. Mỗi tài liệu dẫn trong bài có mục tương ứng ở danh mục cuối báo cáo, có thông tin nhận diện và đường dẫn trực tiếp. Hướng dẫn được dùng làm căn cứ trích dẫn là tài liệu UEH chỉnh sửa ngày 19/5/2025; quy cách bìa và bố cục giữ theo bản đồ án được cung cấp (Đại học Kinh tế Thành phố Hồ Chí Minh, 2025).

# CHƯƠNG 4. KẾT QUẢ PHÂN TÍCH, THIẾT KẾ VÀ TRIỂN KHAI

## 4.1. Tác nhân và yêu cầu nghiệp vụ

Admin quản lý người dùng, thiết bị và công việc hỗ trợ trong tổ chức; Employee theo dõi thiết bị được giao và tạo yêu cầu; Agent gửi thông tin máy và thực hiện các thao tác được cho phép. Các worker nền đánh giá cảnh báo hoặc phát thông báo với tư cách hệ thống, không phải tài khoản con người có quyền đăng nhập.

Hai vai trò đăng nhập là Admin và Employee. Trong các quy trình xử lý, nhân viên IT là người thực hiện công việc dưới quyền Admin, không phải một vai trò Technician riêng. Worker là tiến trình nền xử lý công việc hệ thống. Bảng 4.1 xác định phạm vi trách nhiệm của các chủ thể.

Bảng 4.1: Tác nhân và phạm vi trách nhiệm

| Chủ thể | Phạm vi dữ liệu | Thao tác tiêu biểu |
|---|---|---|
| Admin | Tổ chức đã xác thực | Thiết bị, token, policy, hỗ trợ, cảnh báo, audit. |
| Employee | Máy được giao và yêu cầu hợp lệ của mình | Xem máy, báo vấn đề, phản hồi, chọn ảnh gửi. |
| Agent | Danh tính thiết bị đã đăng ký | Gửi mẫu, poll, kiểm tra lệnh, gửi biên lai. |
| Worker hệ thống | Phạm vi công việc nền được cấu hình | Đánh giá cảnh báo, đẩy thông báo từ hàng đợi sự kiện và dọn dữ liệu kỹ thuật quá hạn. |

Các yêu cầu chức năng được xây dựng theo vòng đời từ thiết lập danh tính đến vận hành và hỗ trợ. Bảng 4.2 liên kết yêu cầu với điều kiện kiểm tra; các nhánh lỗi và cạnh tranh là một phần của chức năng, không chỉ là thông báo trên giao diện.

Bảng 4.2: Yêu cầu chức năng

| Mã | Yêu cầu | Điều kiện cần kiểm tra |
|---|---|---|
| FR01 | Đăng nhập và quản lý phiên | Tổ chức, trạng thái tài khoản, rotation và thu hồi. |
| FR02 | Enrollment thiết bị | Token có hạn, dùng một lần, ghi audit. |
| FR03 | Phân công thiết bị | Cùng tenant; cập nhật quyền Employee. |

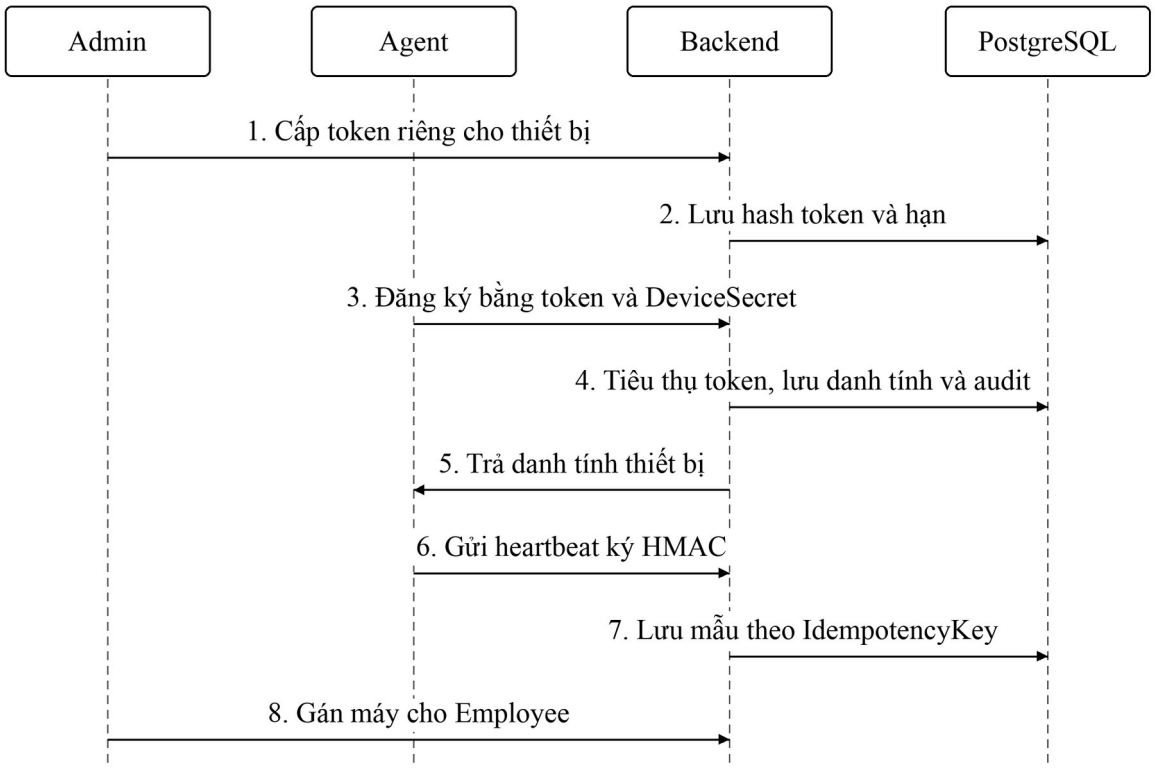
| Mã | Yêu cầu | Điều kiện cần kiểm tra |
|---|---|---|
| FR04 | Telemetry và trạng thái | Giá trị hợp lệ, thời điểm thu thập, idempotency. |
| FR05 | Lệnh và kết quả | Quyền, chữ ký, máy đích, danh sách cho phép, nonce, expiry. |
| FR06 | Chính sách và phòng ban | Policy riêng ưu tiên; kiểm tra mã phiên bản bản ghi (RowVersion / Revision) và tenant. |
| FR07 | Hỗ trợ và ảnh | Đúng máy, quyền sở hữu, xem trước, tải có xác thực. |
| FR08 | Phê duyệt bảo trì | Ràng buộc thiết bị, hạn và cờ cho phép thực thi cục bộ. |
| FR09 | Cảnh báo tự động | Mẫu mới, duy trì, không trùng và không suy diễn Unknown. |
| FR10 | Kiểm toán và vận hành | Lý do/kết quả; snapshot host chỉ đọc. |

Về yêu cầu phi chức năng, hệ thống cần giới hạn dữ liệu theo tổ chức, bảo vệ thông tin xác thực và ghi nhận thay đổi quan trọng. Mất kết nối được xử lý bằng gửi lại có kiểm soát và dữ liệu hàng đợi có giới hạn. Giao diện tiếng Việt ưu tiên tình trạng công việc, đồng thời trình bày rõ thời điểm quan sát để tránh hiểu dữ liệu cũ là trạng thái hiện tại.

### 4.2. Quy trình bàn giao và hỗ trợ

Tiền điều kiện là Admin thuộc tổ chức đang hoạt động và thiết bị được phép tham gia. Admin tạo token hoặc gói enrollment; Agent dùng thông tin đó để đăng ký. Server kiểm tra hạn và trạng thái sử dụng, tạo danh tính máy, lưu bí mật theo cơ chế bảo vệ tương ứng và ghi audit. Token đã dùng hoặc hết hạn không được chấp nhận lại.

Sau đăng ký, Admin gán máy cho Employee trong cùng tổ chức. Employee truy cập endpoint /api/v1/my-device (Thiết bị của tôi) để server tự xác định tài nguyên. Nếu thay đổi người được giao, các yêu cầu tự phục vụ gắn với quan hệ cũ phải được kiểm tra lại trước hành động nhạy cảm. Thu hồi thiết bị làm mất quyền dùng credential cũ, không chỉ đổi nhãn hiển thị trên dashboard.




Hình 4.1: Trình tự đăng ký và bàn giao thiết bị

Nguồn: Tác giả xây dựng.

Mỗi nhân viên chỉ giữ một phân công thiết bị đang hoạt động trong luồng đã nghiệm thu. Khi chuyển sang máy khác, Admin kết thúc phân công cũ rồi gán máy mới. Việc chuyển người sử dụng thay đổi tài nguyên mà cổng Employee có quyền xem; danh tính Agent và thiết bị cũ vẫn được giữ nếu không có thao tác thu hồi.

Nhân viên mô tả vấn đề và cho biết công việc có bị gián đoạn hay không. Giao diện không yêu cầu nhân viên tự phân loại mức độ kỹ thuật. Server gắn yêu cầu với máy đang được phân công; danh sách và chi tiết chỉ trả về trong phạm vi tenant và quyền sở hữu hợp lệ.

Ảnh là dữ liệu tùy chọn do nhân viên chọn. Trước khi gửi, người dùng cần được xem trước và nhận biết dữ liệu sắp chia sẻ. Phản hồi danh sách chỉ chứa metadata ảnh; endpoint tải nội dung kiểm tra quyền riêng. Quy tắc này hạn chế việc vô tình đưa dữ liệu ảnh vào những response tổng hợp và giúp kiểm soát dung lượng truy vấn.

Cổng hỗ trợ có bảy loại yêu cầu: Incident, InstallApp, Privilege, Panic, PauseAgent, UninstallAgent và Appointment. Các loại này sử dụng cùng liên kết

người dùng–thiết bị nhưng có quy tắc xử lý riêng. Đối với Incident, nhân viên chọn nhóm sự cố và mô tả khả năng tiếp tục công việc. Ảnh PNG/JPEG được giới hạn tối đa mười ảnh, mỗi ảnh không quá 2 MiB và phải đúng định dạng tệp.

Yêu cầu hỗ trợ thông thường đi từ Open sang InProgress, có thể chờ phản hồi và sau đó được giải quyết. Giao diện lưu người phụ trách; phản hồi của nhân viên giúp IT xác nhận tình trạng. Yêu cầu phê duyệt phần mềm hoặc bảo trì dùng quyết định riêng, tránh tái sử dụng một quyền đã được cấp bằng cách đổi trạng thái về Open.

InstallApp tham chiếu danh mục ứng dụng do IT cấu hình; ứng dụng được cho phép tự cài có thể xếp lệnh mà không thêm một vòng phê duyệt. Privilege chỉ cấp hành động nằm trong phạm vi được duyệt. Panic tạo cảnh báo khẩn; khả năng tự xếp lệnh cô lập còn phụ thuộc cấu hình lab và điều kiện thực thi tại Agent. Appointment ràng buộc thời gian hẹn lớn hơn năm phút và không quá ba mươi ngày từ lúc tạo.

PauseAgent và UninstallAgent yêu cầu Admin phê duyệt trước khi cấp OTP tám chữ số, dùng một lần, hết hạn sau năm phút và khóa sau năm lần nhập sai. Mã gắn với yêu cầu và thiết bị; quan hệ bàn giao được kiểm tra lại khi sử dụng. Thời lượng PauseAgent lấy từ cấu hình tổ chức, mặc định 15 phút. Lệnh bảo trì được ký như lệnh khác và còn chịu điều kiện quyền cục bộ tại Agent.

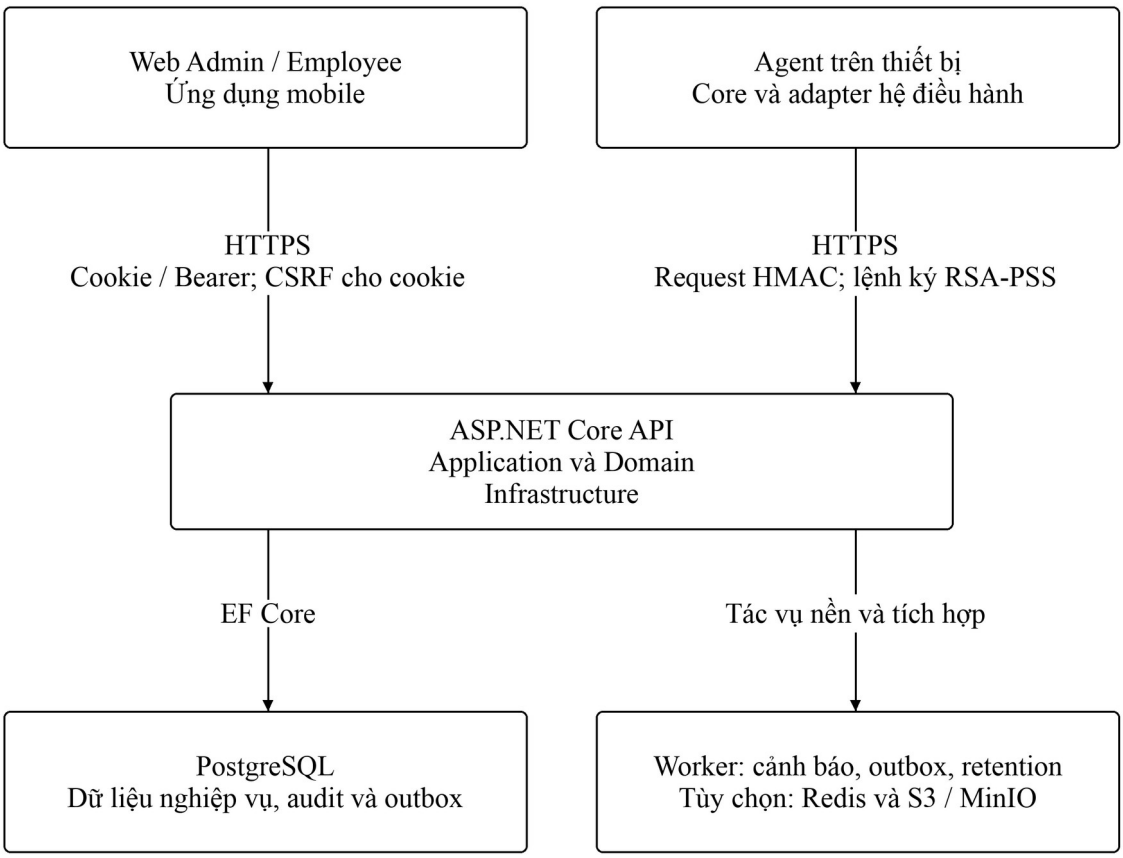
Bảng 4.3: Điểm kiểm soát trong luồng hỗ trợ

| Bước | Dữ liệu hoặc quyết định | Điều kiện nghiệp vụ |
|---|---|---|
| Tạo yêu cầu | Người dùng, máy được giao, loại yêu cầu, nội dung | Máy và người dùng cùng tổ chức; server xác định máy. |
| Gửi ảnh | Tệp đã chọn và sự đồng ý | Xem trước; đúng định dạng, dung lượng và quyền sở hữu yêu cầu. |
| Tiếp nhận | Người phụ trách và trạng thái | Admin có quyền trong tổ chức; cập nhật được lưu audit. |
| Phát lệnh liên quan | Mã lệnh, lý do và quyền đã duyệt | Lệnh hợp lệ, chưa hết hạn, được Agent xác minh. |

| Bước | Dữ liệu hoặc quyết định | Điều kiện nghiệp vụ |
|---|---|---|
| Xác nhận xử lý | Kết quả lệnh và phản hồi hỗ trợ | Phân biệt biên lai kỹ thuật với việc giải quyết yêu cầu của nhân viên. |

### 4.3. Kiến trúc và các thành phần triển khai

Web Admin, web Employee và mobile giao tiếp với backend qua API có xác thực. Agent gửi request theo danh tính máy. PostgreSQL lưu trạng thái nghiệp vụ; các worker xử lý giám sát, outbox và dọn dữ liệu kỹ thuật. Redis backplane và lưu ảnh S3 hoặc MinIO là adapter tùy chọn, cần cấu hình và nghiệm thu riêng.




Hình 4.2: Thành phần hệ thống và hướng giao tiếp

Nguồn: Tác giả xây dựng.

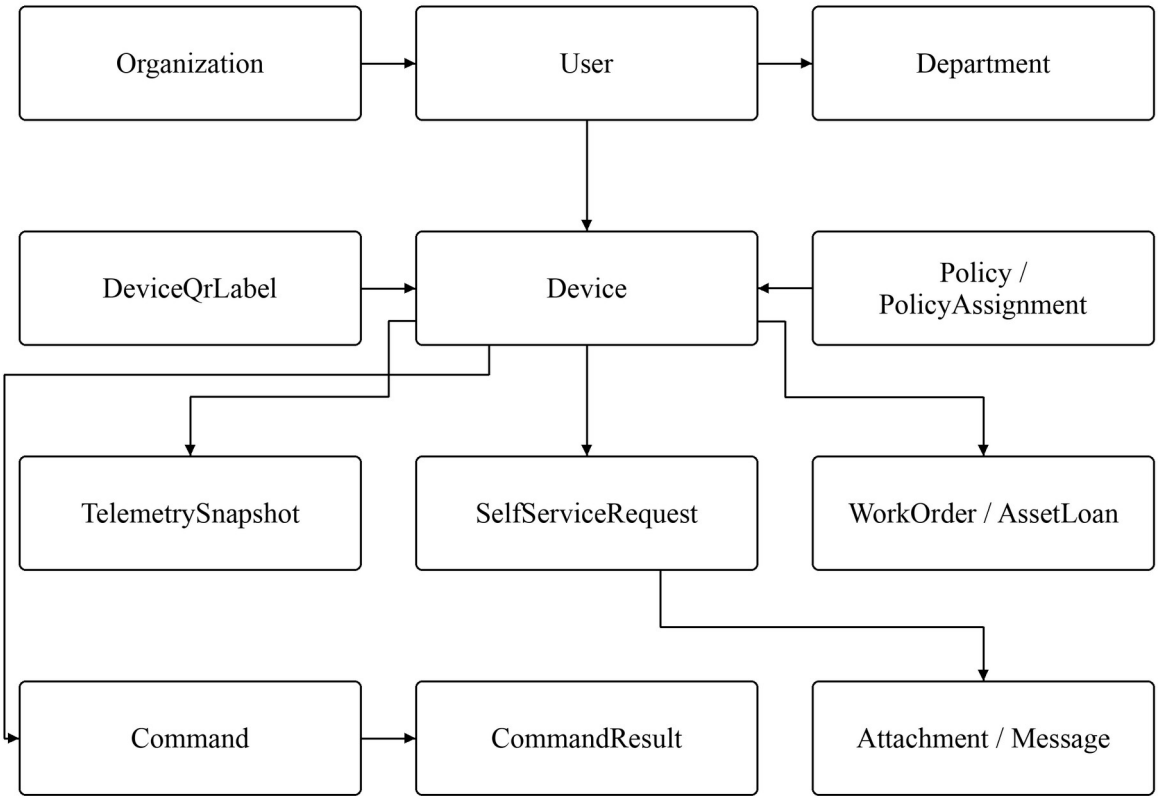
Các project Domain giữ entity và quy tắc trạng thái; Application điều phối ca sử dụng qua interface; Infrastructure cung cấp EF Core, dịch vụ nền và tích hợp; Api đăng ký phụ thuộc, ánh xạ endpoint và xác thực giao tiếp. Kiểm thử kiến trúc kiểm tra chiều tham chiếu giữa các project. Cách phân chia này cho phép kiểm tra quyết định nghiệp vụ bằng adapter thử mà không gọi hệ điều hành thật.

Các thành phần chính nằm tại apps/backend, apps/agent, apps/company, apps/employee và apps/mobile. packages/web-ui giữ phần giao diện dùng chung. Cấu trúc này cho phép chia sẻ client API có kiểu và thành phần hiển thị, nhưng việc dùng chung không thay thế kiểm tra quyền trên backend.

Endpoint dành cho người dùng lấy tổ chức từ phiên đã xác thực. Endpoint /api/v1/my-device để máy chủ xác định thiết bị đang bàn giao; endpoint Agent sử dụng danh tính máy. Cơ chế outbox ghi sự kiện cùng thay đổi nghiệp vụ trước khi worker gửi thông báo, giảm khoảng trống giữa cập nhật dữ liệu và phát tín hiệu.

### 4.4. Mô hình dữ liệu và tính nhất quán

Các nhóm dữ liệu chính gồm tổ chức và người dùng, thiết bị và telemetry, lệnh và kết quả, yêu cầu hỗ trợ và tệp đính kèm. Audit liên kết hành động với chủ thể và thời điểm. Department cung cấp cơ cấu phân công và policy mặc định; outbox lưu các sự kiện cần được phát sau giao dịch.




Quan hệ nghiệp vụ chọn lọc; không thay thế lược đồ khóa ngoại.

Hình 4.3: Mô hình quan hệ nghiệp vụ chọn lọc

Nguồn: Tác giả xây dựng.

Định danh chủ yếu dùng UUID; các mốc thời gian sử dụng UTC. Dữ liệu thuộc tổ chức có OrganizationId. Device.AssignedUserId có thể rỗng khi chưa phân công. Trường này là một phần của điều kiện truy cập, không chỉ là thông tin mô tả thiết bị.

Bảng 4.4: Nhóm dữ liệu và ràng buộc chính

| Nhóm | Trường hoặc quan hệ tiêu biểu | Bất biến cần giữ |
|---|---|---|
| Organization / User | OrganizationId, Code, Status, SecurityStamp | Mọi tài khoản và phiên được kiểm tra đúng tổ chức. |
| Device | AssignedUserId, DepartmentId, IsRevoked | Phân công quyết định phạm vi Employee; thu hồi chặn Agent. |
| EnrollmentToken | Token hash, ExpiresAt, UsedAt | Hết hạn hoặc đã sử dụng không tiêu thụ lại. |
| DeviceHeartbeat | DeviceId, IdempotencyKey | Cặp khóa duy nhất ngăn tạo mẫu trùng. |
| TelemetrySnapshot | Số đo và thời điểm | Dữ liệu cũ không đại diện trạng thái hiện tại. |
| Command / Result | DeviceId, nonce, signature, expiry, command ID | Không ghi đè kết quả gốc khi biên lai lặp. |
| SelfServiceRequest | UserId, DeviceId, Kind, Status | Kiểm tra tenant và quan hệ phân công hiện hành. |
| Attachment | Size, Content hoặc ObjectKey | Danh sách chỉ metadata; nội dung tải qua endpoint riêng. |
| Department / Policy | OrganizationId, policy mặc định, revision | Tham chiếu cùng tenant; tránh ghi đè đồng thời. |
| Audit / Outbox | Action, Outcome; processed time | Audit không sửa qua EF; outbox chưa xử lý không bị dọn. |

Cặp DeviceId–IdempotencyKey giữ tính duy nhất của heartbeat. Khi gửi lại một mẫu, máy chủ trả kết quả đã nhận thay vì tạo một mẫu mới. Các trường phiên bản và điều kiện cập nhật hỗ trợ phát hiện hai request cùng tiêu thụ token hoặc thay đổi trạng thái. Quan hệ phòng ban và chính sách được kiểm tra cùng tổ chức.

Lược đồ được quản lý bằng migration EF Core. Việc áp dụng migration trên PostgreSQL xác định bảng, chỉ mục và ràng buộc thực tế; mô hình quan hệ ở Hình

4.3 phục vụ diễn giải nghiệp vụ. Các kiểm thử dùng InMemory được ghi đúng provider vì không tái tạo đầy đủ giao dịch và khóa của PostgreSQL.

## 4.5. Thiết kế xác thực và bảo vệ dữ liệu

### 4.5.1. Xác thực và phân quyền người dùng

Phiên người dùng gắn với tổ chức, trạng thái tài khoản và SecurityStamp. Web dùng cookie HttpOnly và bảo vệ CSRF cho yêu cầu thay đổi dữ liệu. Refresh token được lưu dưới dạng hash, có FamilyId và quan hệ phiên thay thế. Dùng lại token đã thay thế dẫn tới thu hồi chuỗi phiên liên quan.

Mật khẩu được băm bằng PBKDF2-HMAC-SHA256 với salt ngẫu nhiên và số vòng lặp theo cấu hình. Phép so sánh được thực hiện theo thời gian cố định; mật khẩu hợp lệ có tham số băm cũ được yêu cầu nâng cấp. Cơ chế dẫn xuất khóa được mô tả trong RFC 8018 (Moriarty và cộng sự, 2017).

Quyền truy cập được kiểm tra theo tổ chức và quan hệ tài nguyên tại lớp nghiệp vụ, có bộ lọc dữ liệu bổ sung ở tầng lưu trữ. Các kết nối thời gian thực được xác minh lại định kỳ và đóng khi phiên không còn hợp lệ.

### 4.5.2. Xác thực thiết bị

Enrollment dùng token một lần để thiết lập danh tính ban đầu. Sau chuyển đổi sang cơ chế request HMAC S1, mỗi Agent dùng khóa chuyên dụng của chính nó. Nội dung ký ràng buộc request với các thành phần giao tiếp và dữ liệu cần kiểm tra; server giữ nonce chống phát lại. Credential bị thu hồi phải bị từ chối ở đường gửi telemetry và poll.

Khóa HMAC riêng của thiết bị xác thực request Agent; khóa RSA trên máy chủ ký lệnh gửi xuống Agent. Hai cơ chế bảo vệ hai hướng giao tiếp và có vòng đời khóa riêng. Mật khẩu hoặc credential của một máy không cung cấp khả năng ký lệnh thay máy chủ.

Nếu máy chủ đã tiếp nhận đăng ký nhưng phản hồi bị mất, Agent có thể gửi lại bằng chứng đã lưu. Máy chủ chỉ khôi phục danh tính khi token còn hạn, thông

tin thiết bị và khóa xác thực khớp, credential chưa bị thu hồi và quá trình xác thực ban đầu chưa hoàn tất.

Khi khôi phục hợp lệ, máy chủ trả lại danh tính đã tạo và ghi nhận sự kiện đăng ký được phục hồi. Cách xử lý này tránh tạo thiết bị trùng trong khi vẫn giữ giới hạn sử dụng token.

### 4.5.3. Bảo vệ dữ liệu và nhật ký

Nội dung hỗ trợ được bảo vệ bằng AES-256-GCM. Dữ liệu xác thực bổ sung phân biệt mục đích sử dụng của từng trường, hỗ trợ phát hiện bản mã bị thay đổi hoặc sử dụng sai ngữ cảnh. Quyền truy cập yêu cầu và ảnh vẫn được kiểm tra độc lập tại lớp nghiệp vụ (Dworkin, 2007).

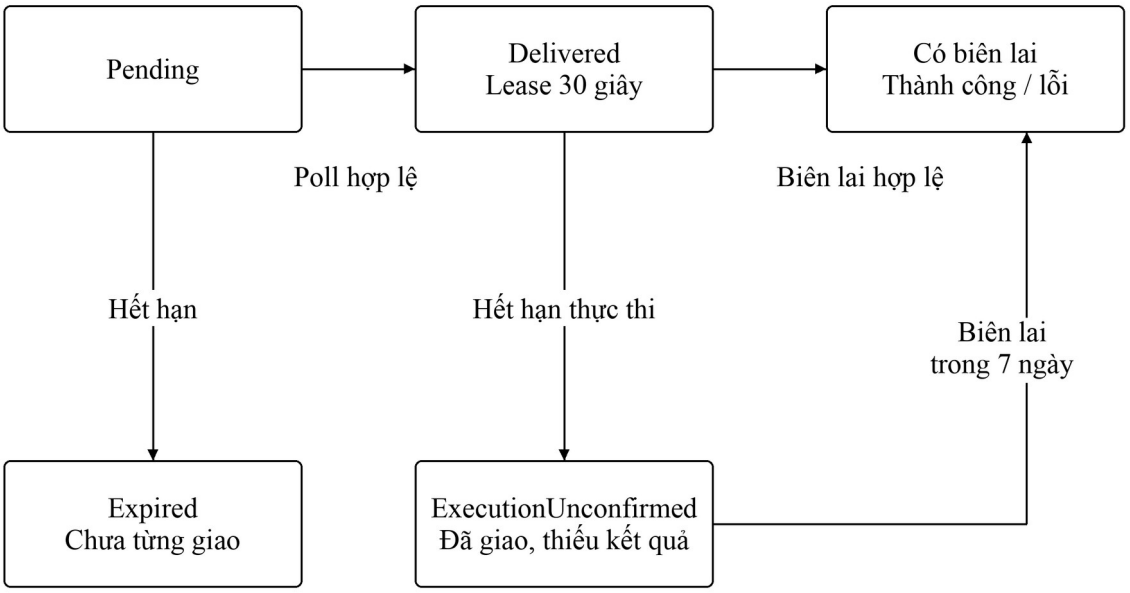
Audit lưu chủ thể, tài nguyên, hành động, lý do, thời điểm và kết quả. DbContext chặn sửa hoặc xóa AuditLog qua đường ghi EF. Quyền của quản trị viên cơ sở dữ liệu và nơi giữ khóa mã hóa thuộc phạm vi vận hành; bản sao lưu và cấu hình triển khai phải được quản lý theo quyền tương ứng.

## 4.6. Thiết kế giao lệnh và biên lai

Lệnh được ký bằng RSA-PSS và gắn với thiết bị đích, người phát hành, lý do, thời hạn cùng mã chống phát lại. Nội dung đã ký được giữ nguyên khi giao lại; Agent xác minh trước khi thực hiện.

Agent xác minh khóa công khai đã được cấp qua bộ cài hoặc cấu hình tin cậy, kiểm tra chữ ký, máy đích, hạn, loại lệnh và nonce trước khi thực thi. Luân chuyển khóa cần phối hợp giữa cấu hình xác minh của Agent và khóa ký trên máy chủ.

Server cấp lease giao nhận 30 giây cho lệnh phù hợp, bị giới hạn bởi hạn bắt đầu thực thi. Khi response poll bị mất, lệnh có thể được giao lại sau khi lease hết hạn với cùng ID, nonce và chữ ký. Agent ưu tiên gửi lại biên lai đang lưu trước khi nhận công việc khác.




Giao lại giữ ID, nonce và chữ ký; chưa bảo đảm exactly-once.

Hình 4.4: Vòng đời giao lệnh và nhận kết quả

Nguồn: Tác giả xây dựng.

ExpiresAt là hạn cho phép bắt đầu thực thi, còn cửa sổ nhận biên lai kéo dài bảy ngày sau hạn đó. Cửa sổ nhận kết quả không gia hạn quyền thực thi. Lệnh chưa từng giao có thể trở thành Expired; lệnh đã giao mà chưa có biên lai chuyển sang ExecutionUnconfirmed. Hai trạng thái khác nhau vì server không đủ bằng chứng kết luận thiết bị chưa từng thực hiện lệnh đã giao.

Agent lưu nonce trước khi gọi adapter và lưu biên lai sau thao tác. Nếu tiến trình dừng giữa hai bước, nonce ngăn tự thực hiện lại nhưng máy chủ có thể chưa nhận được kết quả. Trạng thái ExecutionUnconfirmed giữ lại tình huống này để IT kiểm tra trước khi yêu cầu thao tác mới.

Bản triển khai cho phép Agent và API khác số phiên bản khi còn đáp ứng hợp đồng giao tiếp, phương thức xác thực và khóa tin cậy. Trong phiên nghiệm thu, Agent 1.0.4 trao đổi thành công với API tại commit af4fb1d. Kết quả này xác nhận khả năng tương thích của cặp phiên bản được thử.

### 4.7. Agent Windows và các điều kiện thực thi

Agent Core quản lý chu kỳ, queue và kiểm tra lệnh. Infrastructure cung cấp HTTP, bộ lấy mẫu và lưu trữ được bảo vệ. Worker ghép cấu hình để chạy như Windows Service hoặc nền tảng được hỗ trợ. Cách tách này cho phép unit test vòng đời và mô phỏng lỗi mà không sửa firewall hay dịch vụ thật của máy phát triển.

Telemetry kỹ thuật gồm CPU theo khoảng lấy mẫu, RAM vật lý và mức dùng ổ hệ thống. Mẫu CPU đầu có thể bằng không nếu chưa đủ khoảng đo; không nên gọi đó là độ chính xác tuyệt đối. Queue production trong hồ sơ có giới hạn 50 mẫu và thời gian một giờ, vì vậy mất mạng kéo dài có thể dẫn tới mất lịch sử ngoài chính sách lưu cục bộ.

Agent chạy dưới dạng Windows Service với quyền điều khiển dịch vụ được giới hạn. Những thao tác cần phiên người dùng được chuyển qua thành phần tương tác cục bộ có kiểm tra quyền, phiên làm việc và mã lệnh.

Inventory kèm thời điểm thu thập và không ghi đè tùy tiện dữ liệu tài sản được nhập thủ công. Trạng thái bảo vệ có thể là Unknown hoặc NotSupported khi thiếu khả năng quan sát. Đối chiếu phần mềm dựa trên ProductCode hoặc UpgradeCode trong quy tắc đã cấu hình; ứng dụng portable hoặc ngoài phạm vi kiểm kê có thể chưa được phát hiện.

Hai thao tác SimulateLock và SimulateNetworkIsolation phục vụ mô phỏng. Nhánh cô lập mạng thật chỉ được phép trên thiết bị lab đã cấu hình, có quyền phù hợp và tác vụ khôi phục được xác nhận trước khi áp dụng. Các điều kiện này giới hạn tác động khi thử nghiệm trên Windows.

Ứng dụng được duyệt chỉ được tải từ nguồn HTTPS tin cậy, kiểm tra kích thước, mã băm và chữ ký nhà phát hành trước khi cài đặt. Hạn phê duyệt được kiểm tra lại ở thời điểm thực hiện. Luồng này tách biệt với bộ Setup.exe dùng để cài Agent.

### 4.8. Tài sản, chính sách và bảo trì

Hồ sơ tài sản liên kết thiết bị với thông tin nhà sản xuất, dòng máy, số sê-ri, vị trí sử dụng, thời điểm mua và bảo hành. Những dữ liệu quản trị này bổ sung ngữ cảnh cho việc bàn giao, bảo trì và lập kế hoạch thay thế.

AssetLoan ghi người mượn, người duyệt, thời điểm bàn giao, hạn trả và tình trạng trước–sau. WorkOrder tổ chức công việc sửa chữa hoặc phòng ngừa; khi hoàn thành ghi chi phí linh kiện và lao động. Tổng chi phí bằng hai khoản này cộng lại, còn giờ lao động được theo dõi riêng.

Tem QR nhận diện tài sản được tách khỏi thông tin xác thực Agent. Tra cứu công khai tại GET /api/v1/qr/{code}/public chỉ cung cấp thẻ thiết bị tối giản và hướng dẫn liên hệ IT. Thông tin người sử dụng và dữ liệu giám sát không được trả trong thẻ công khai.

Tra cứu tại GET /api/v1/qr/{code} yêu cầu đăng nhập và kiểm tra thiết bị trong đúng tổ chức. Admin được điều hướng tới trang thiết bị; Employee chỉ xem được máy đang bàn giao cho mình. Tem hết hạn hoặc đã thu hồi không cấp quyền truy cập.

Policy riêng của máy ưu tiên hơn mặc định phòng ban. Khi thay đổi policy hoặc phân công, server có thể xếp lệnh RefreshPolicy. Việc bỏ policy ở database không tự chứng minh mọi thay đổi trước đó trên hệ điều hành đã được hoàn tác. Cần cơ chế thay thế hoặc nghiệm thu trạng thái thực tế theo từng adapter.

Các ngưỡng mặc định gồm CPU/RAM 90%, ổ đĩa 95%, thời gian mất kết nối và duy trì cảnh báo năm phút. Một thiết bị và quy tắc chỉ có một cảnh báo tự động đang mở. Worker bảo trì tạo phiếu theo chu kỳ hoặc thời hạn bảo hành, có khóa chống trùng. Các giá trị này là tham số thiết kế, có thể điều chỉnh theo cấu hình tổ chức sau khi có dữ liệu vận hành phù hợp.

### 4.9. Triển khai VPS và kiểm tra nguồn phiên bản

Bản triển khai sử dụng Docker Compose cho API, cổng Company, cổng Employee và PostgreSQL, với các thành phần proxy/TLS đứng trước giao diện. Agent chạy trên thiết bị Windows. Cấu hình môi trường và khóa được đặt ngoài mã

nguồn; quy trình phát hành cần giữ thông tin commit gắn với image để đối chiếu bản đang chạy.

Ngày 26/10/2026, API trả trạng thái ready. Thông tin phiên bản từ API và image trên màn giám sát cùng xác định commit af4fb1d. Kết quả cho phép đối chiếu mã nguồn của API đang vận hành với bản triển khai được nghiệm thu.




Hình 4.5: Image API trên VPS mang commit af4fb1d

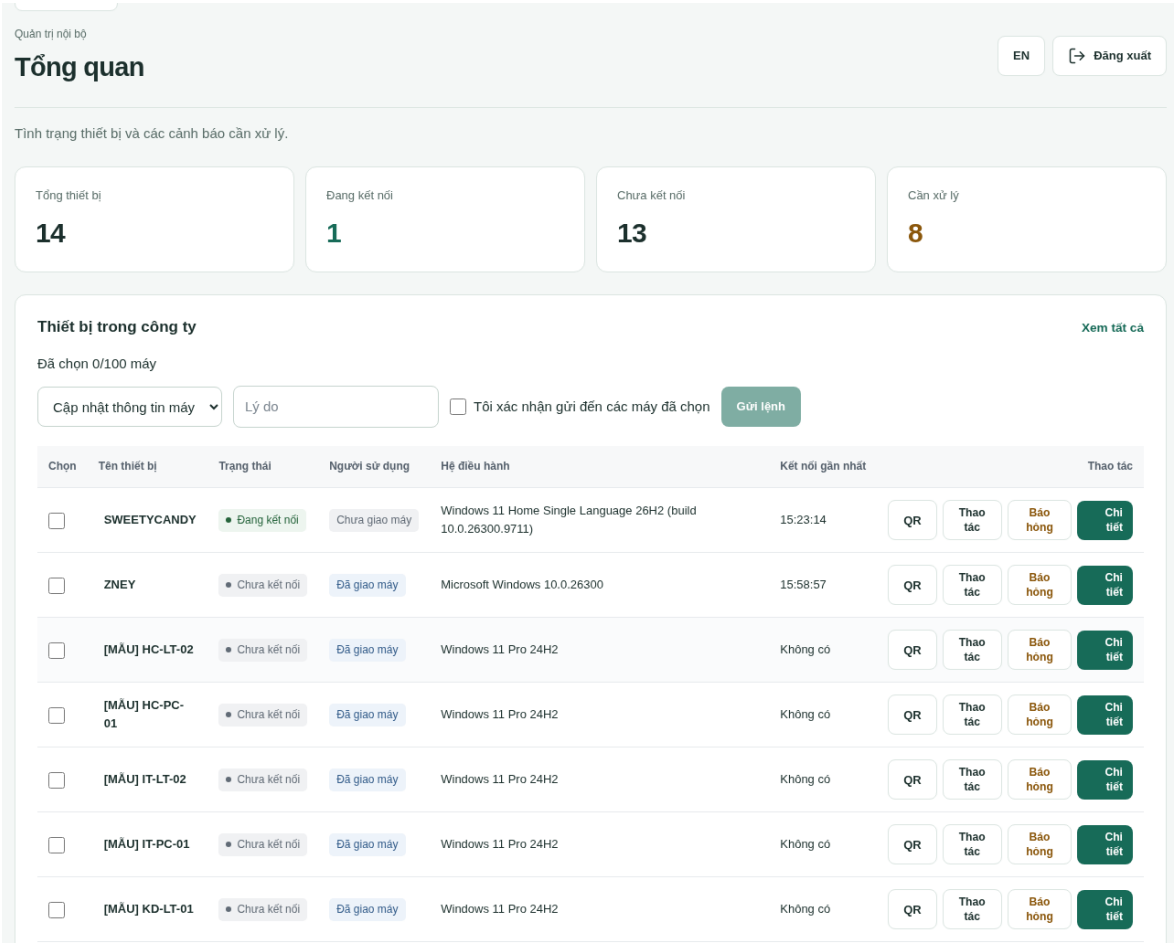
Nguồn: Hệ thống SentinelLAN.

Màn giám sát hiển thị bảy container SentinelLAN đang chạy và PostgreSQL có trạng thái healthy. Các trang CPU, RAM, ổ đĩa, dịch vụ và cổng đang nghe cung cấp dữ liệu phục vụ người vận hành. Tổng số container toàn VPS còn bao gồm ứng dụng khác nên không được dùng làm chỉ tiêu riêng của SentinelLAN.

Sao lưu phục hồi cần bao gồm cơ sở dữ liệu, khóa mã hóa và cấu hình tương ứng. Một bản sao lưu mã hóa chỉ hoàn tất chu trình bảo vệ sau khi thử phục hồi và đọc dữ liệu ở môi trường tách biệt. Phiên nghiệm thu web chỉ quan sát giám sát, không thay đổi dịch vụ VPS hoặc thực hiện phục hồi.

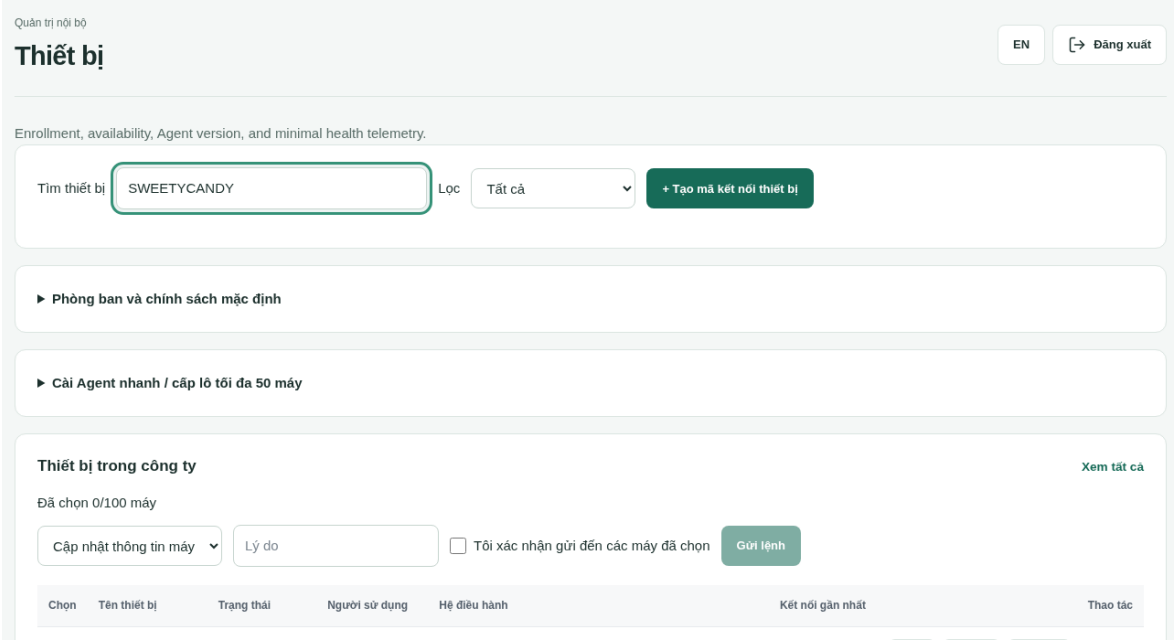
## 4.10. Giao diện và nghiệm thu quy trình triển khai

Các hình trong mục này ghi nhận trực tiếp quy trình trên hệ thống triển khai ngày 26/10/2026. Ảnh gốc và dữ liệu quan sát được lưu trong hồ sơ nghiệm thu; hình chèn trong báo cáo giữ nguyên nội dung của vùng giao diện được trình bày.




Hình 4.6: Tổng quan quản trị trên hệ thống đã triển khai

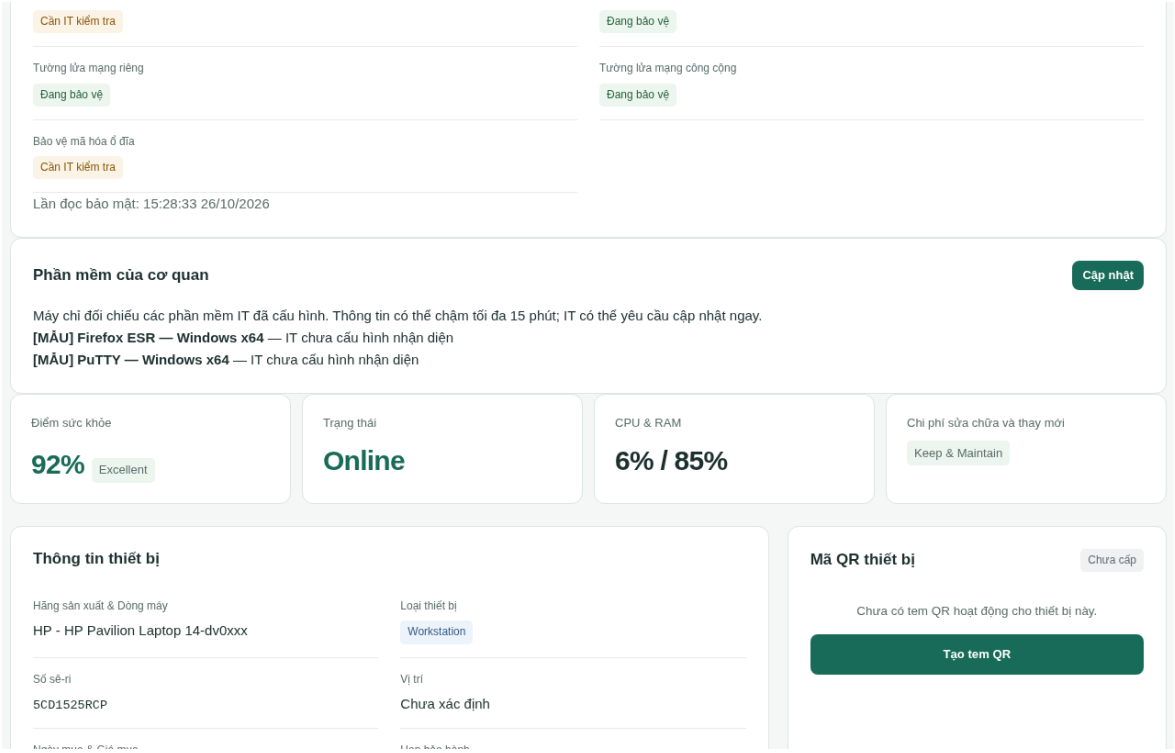
Nguồn: Hệ thống SentinelLAN.




Hình 4.7: Admin tìm thiết bị SWEETYCANDY trước bàn giao

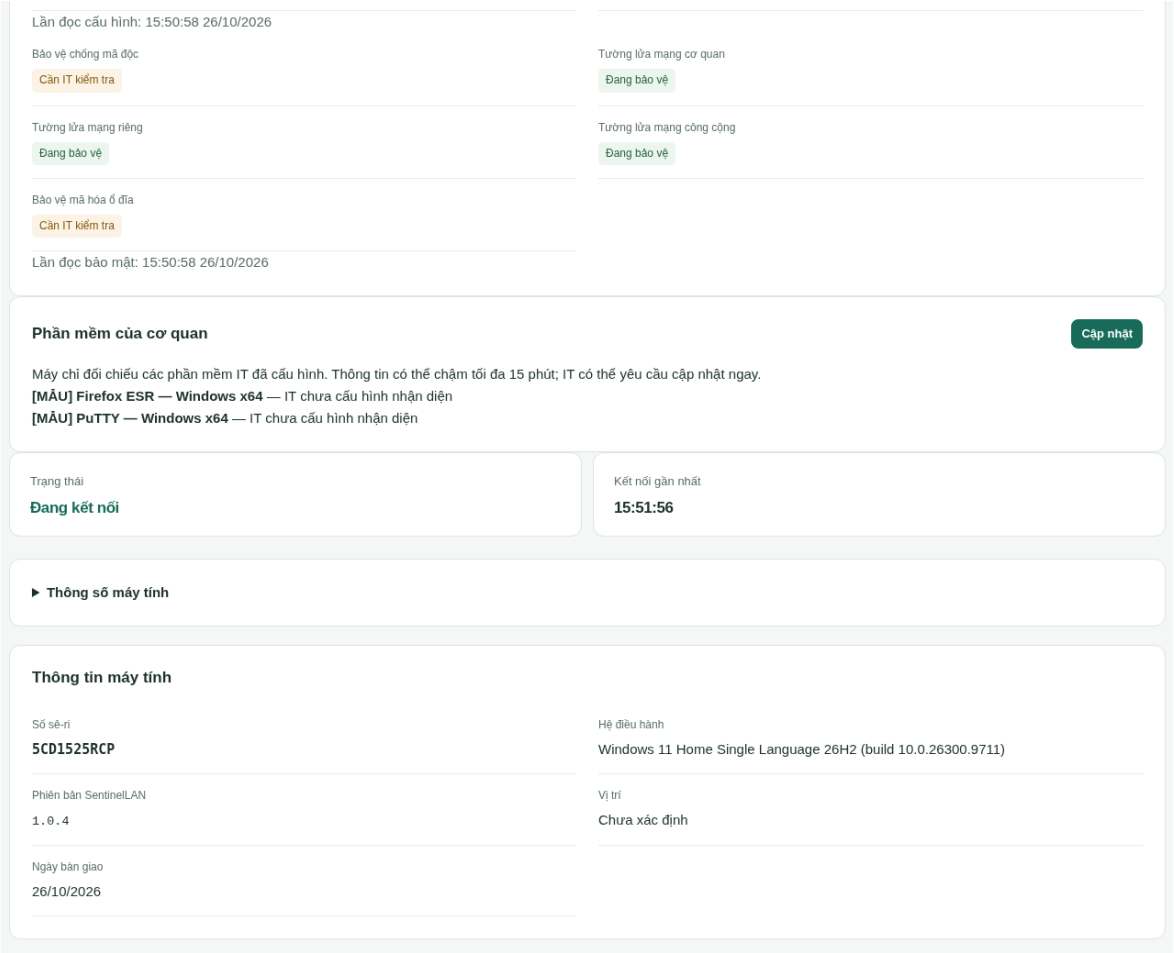
Nguồn: Hệ thống SentinelLAN.

Trước bàn giao, SWEETYCANDY đã có Agent kết nối nhưng chưa được gán cho Employee. Lần gán đầu trả xung đột vì Employee còn giữ máy ZNEY. Admin kết thúc phân công máy cũ rồi gán SWEETYCANDY; tải lại trang ở hai vai trò xác nhận máy mới. Danh tính của hai máy được giữ nguyên.




Hình 4.8: SWEETYCANDY Online và đã có người sử dụng

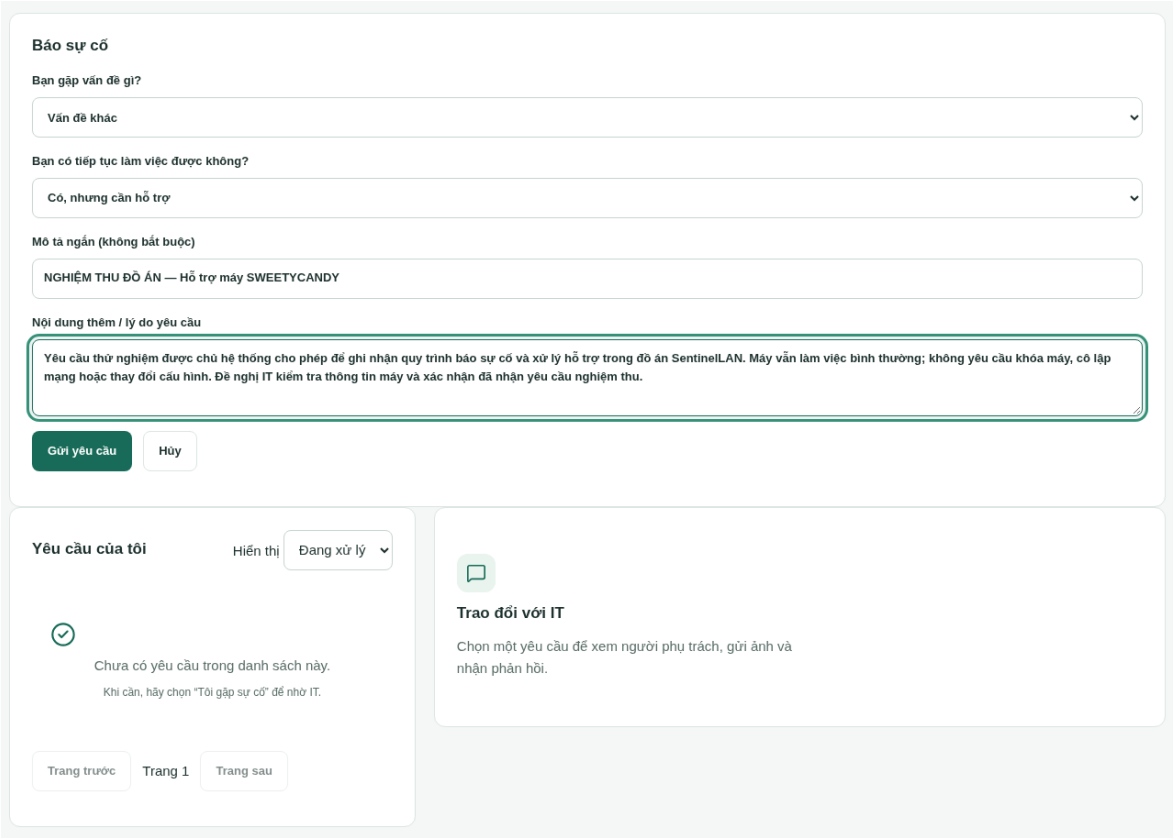
Nguồn: Hệ thống SentinelLAN.




Hình 4.9: Employee xem máy được bàn giao và heartbeat mới

Nguồn: Hệ thống SentinelLAN.

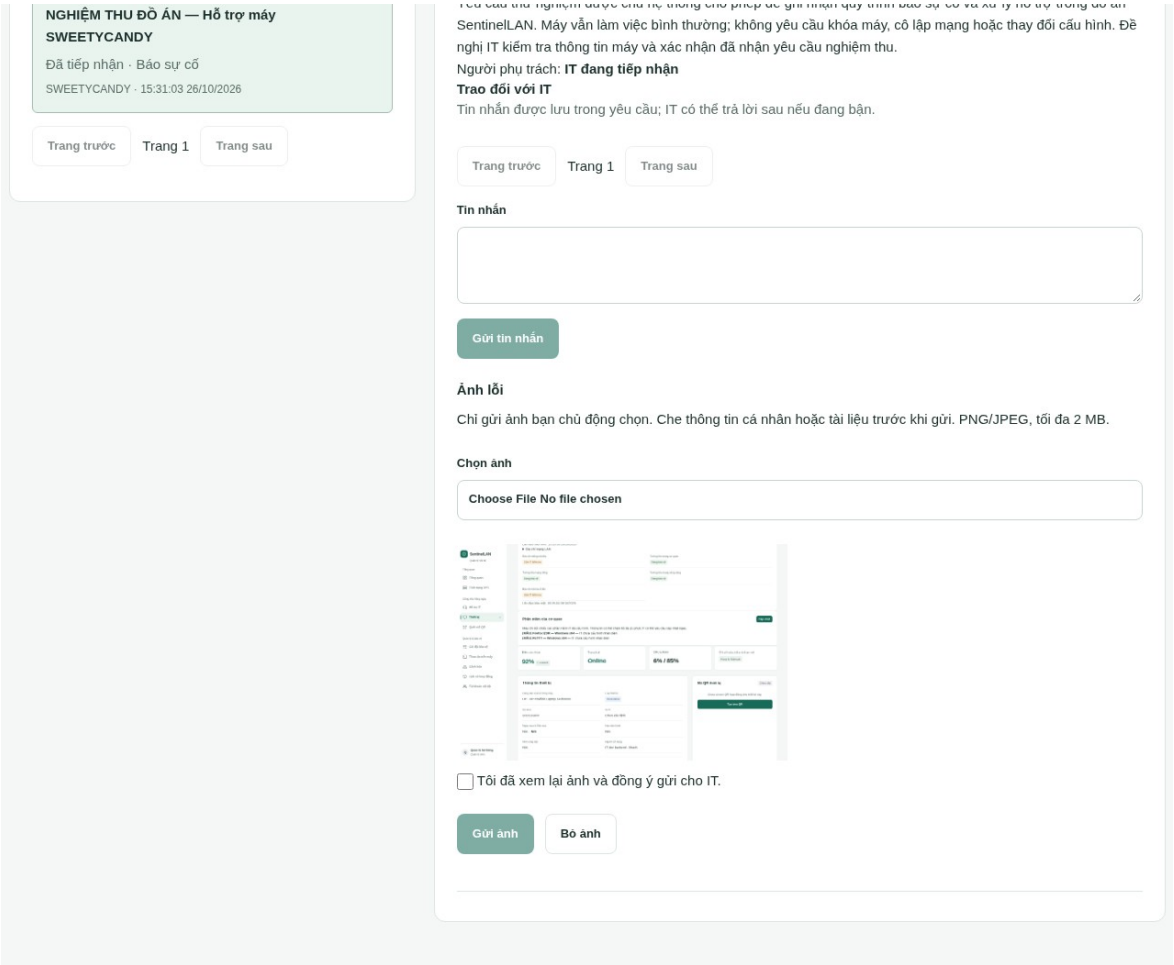
Employee tạo một yêu cầu hỗ trợ nghiệm thu gắn với máy SWEETYCANDY đang được bàn giao. Nội dung xác định máy vẫn hoạt động và đề nghị IT kiểm tra thông tin kết nối, không mô tả đây là một sự cố hỏng máy thực tế.




Hình 4.10: Employee mô tả yêu cầu hỗ trợ nghiệm thu

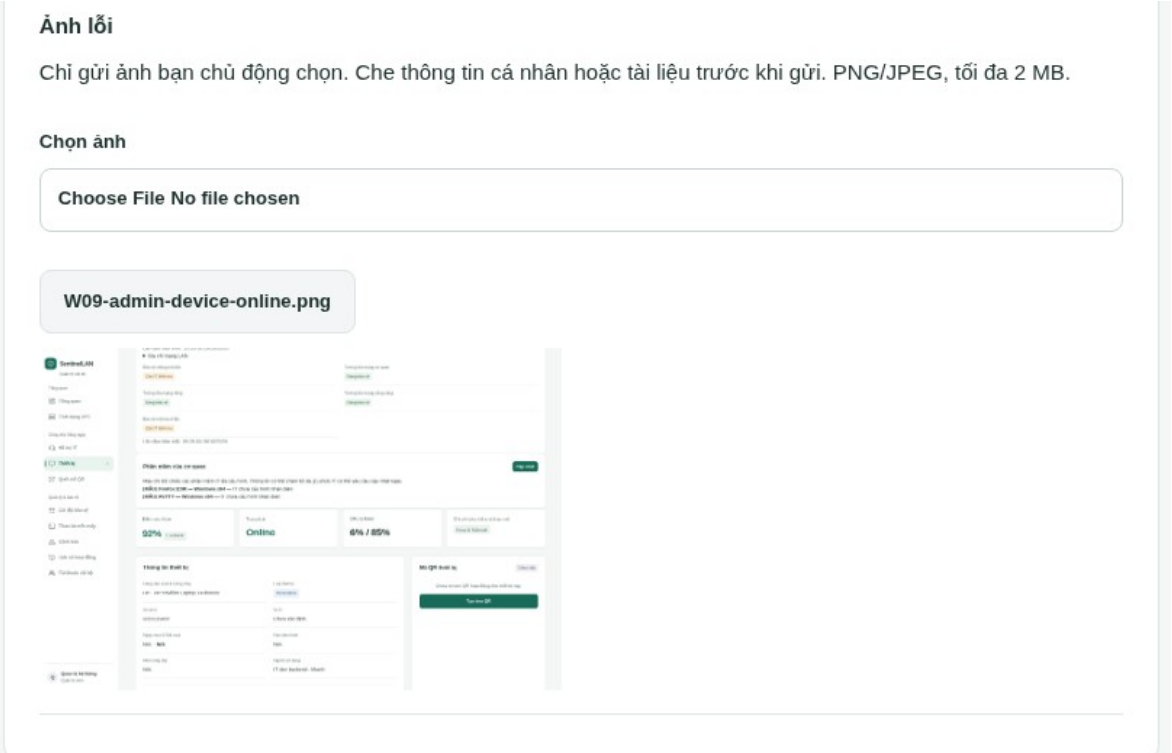
Nguồn: Hệ thống SentinelLAN.

Employee chọn ảnh thông số máy làm minh chứng, xem trước và xác nhận đồng ý trước khi gửi. Sau tải lên, Admin mở được ảnh trong đúng yêu cầu. Bước này kiểm tra luồng ảnh do người dùng lựa chọn, không phải chức năng Agent tự chụp màn hình.




Hình 4.11: Xem trước ảnh và yêu cầu đồng ý trước khi gửi

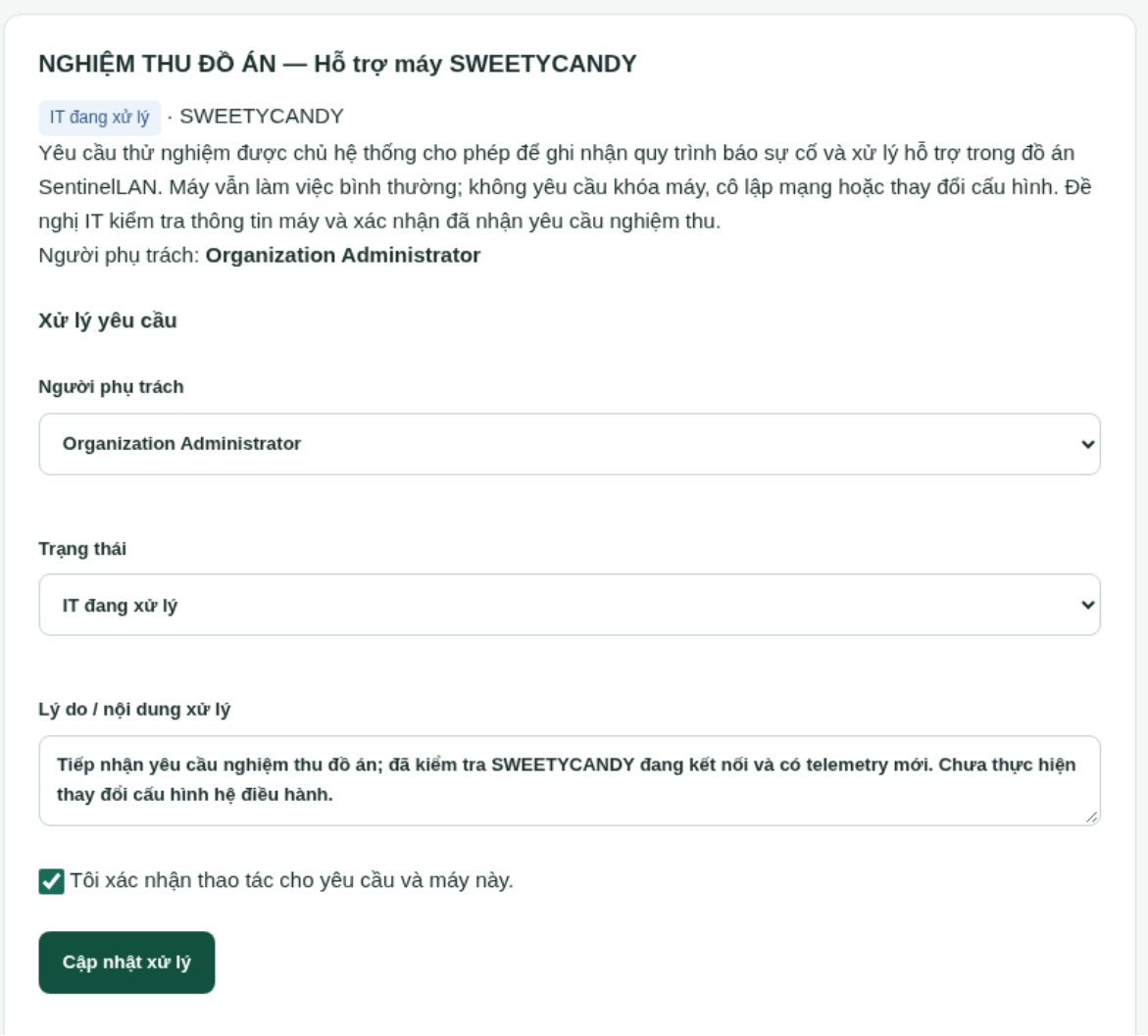
Nguồn: Hệ thống SentinelLAN.




Hình 4.12: Ảnh đính kèm hiển thị trong cổng Admin

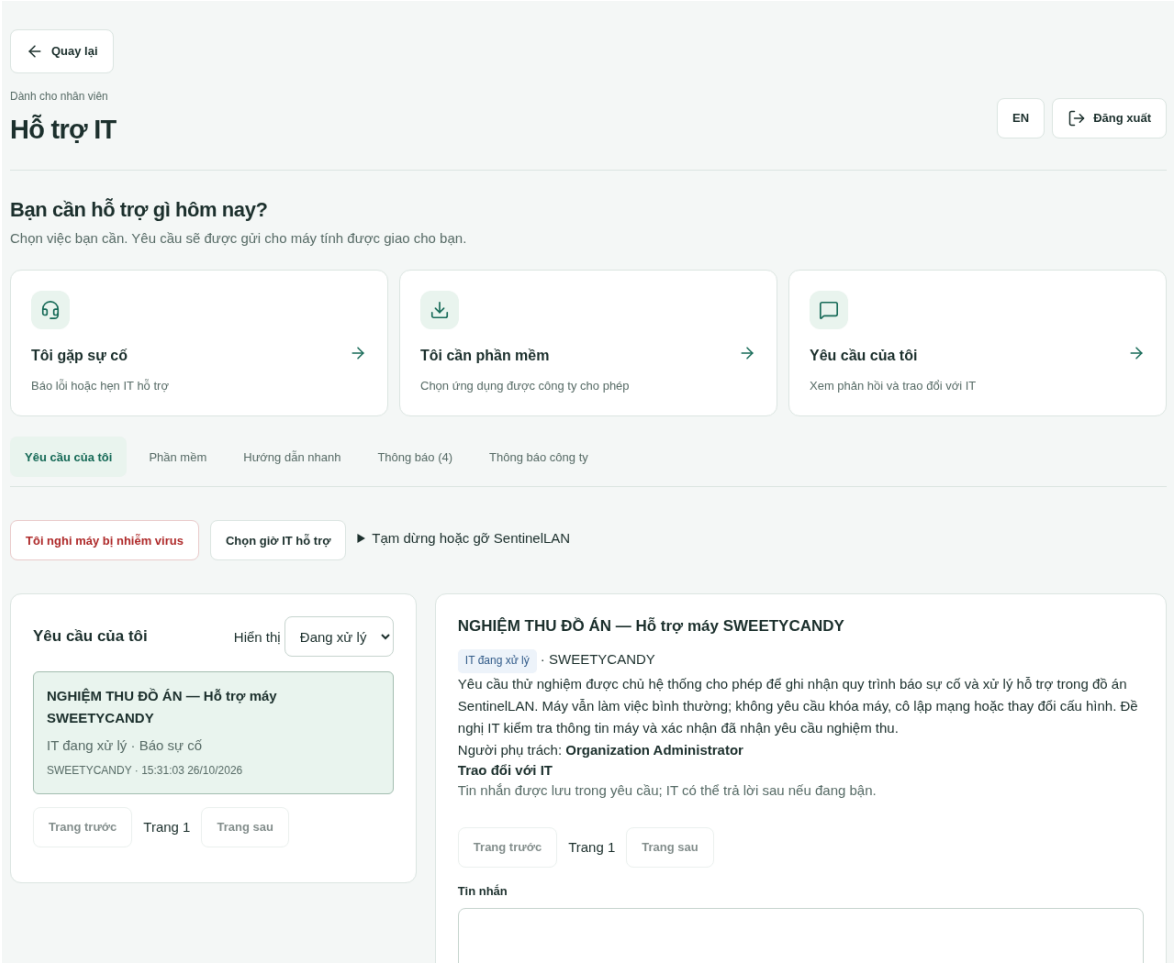
Nguồn: Hệ thống SentinelLAN.

Admin phân công người phụ trách và chuyển yêu cầu sang InProgress. Employee nhìn thấy cùng trạng thái và người xử lý. Phiên nghiệm thu dừng ở bước tiếp nhận; yêu cầu chưa được chuyển thành đã giải quyết.




Hình 4.13: IT tiếp nhận và phân công yêu cầu hỗ trợ

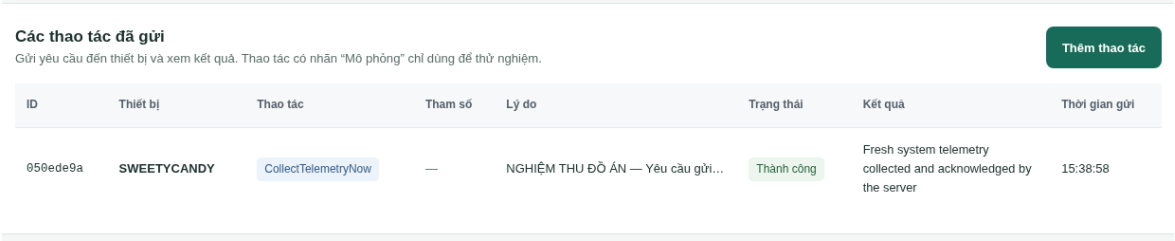
Nguồn: Hệ thống SentinelLAN.




Hình 4.14: Employee theo dõi trạng thái IT đang xử lý

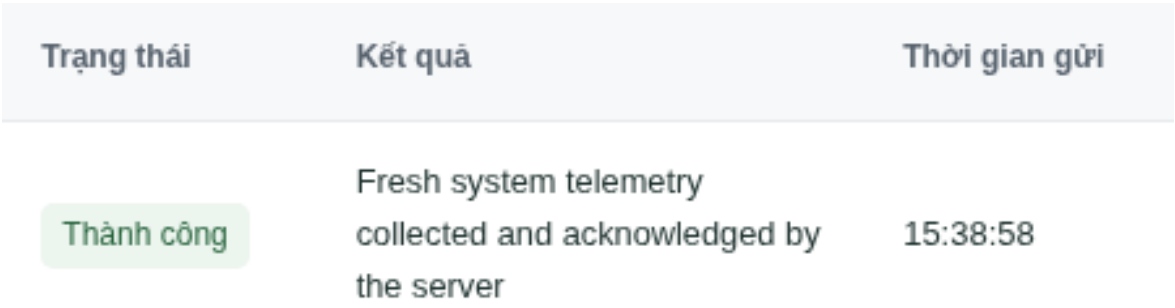
Nguồn: Hệ thống SentinelLAN.

Admin phát lệnh CollectTelemetryNow với lý do và xác nhận. Agent trả biên lai Succeeded; audit ghi nhận việc tạo và hoàn thành lệnh. Kết quả xác nhận thông số mới đã được thu và máy chủ tiếp nhận, không bao gồm thay đổi chính sách hệ điều hành.



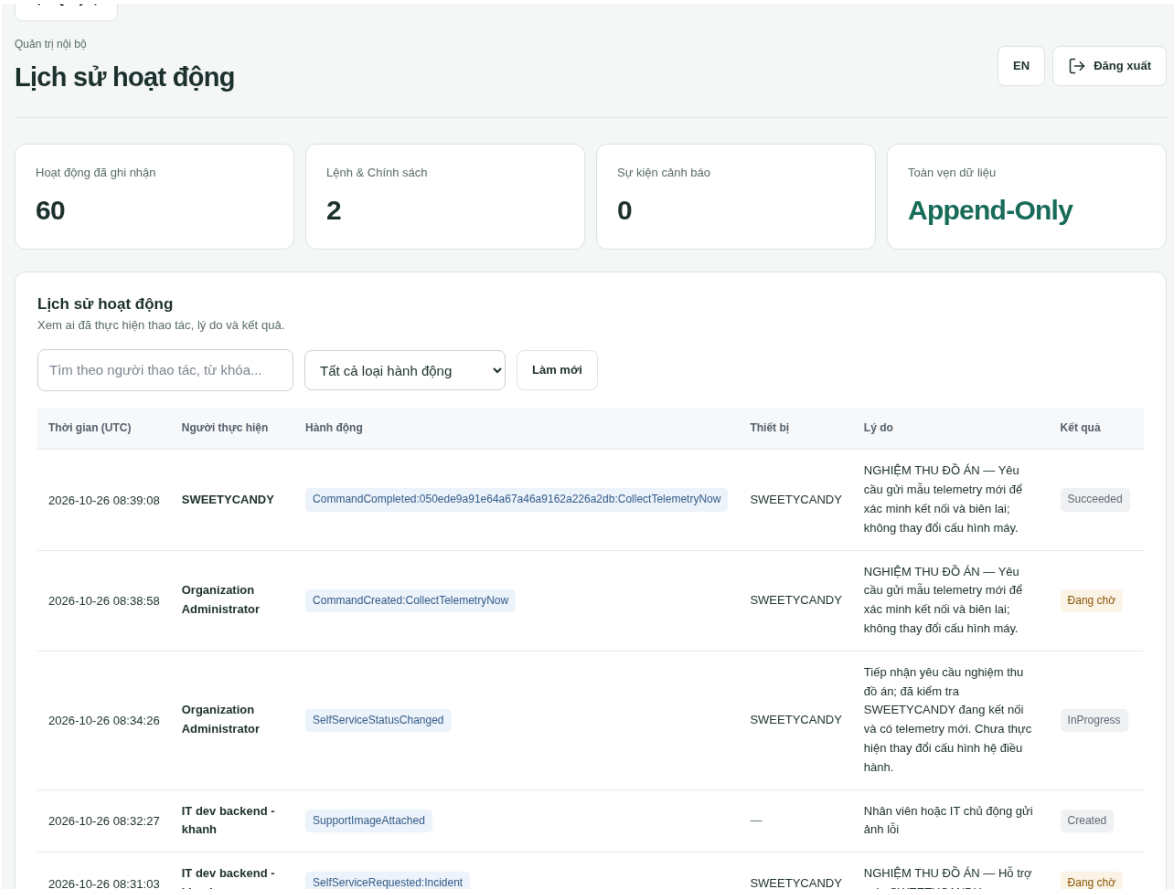

Hình 4.15: Lệnh CollectTelemetryNow có trạng thái thành công

Nguồn: Hệ thống SentinelLAN.




Hình 4.16: Chi tiết biên lai Agent và kết quả cập nhật thông số

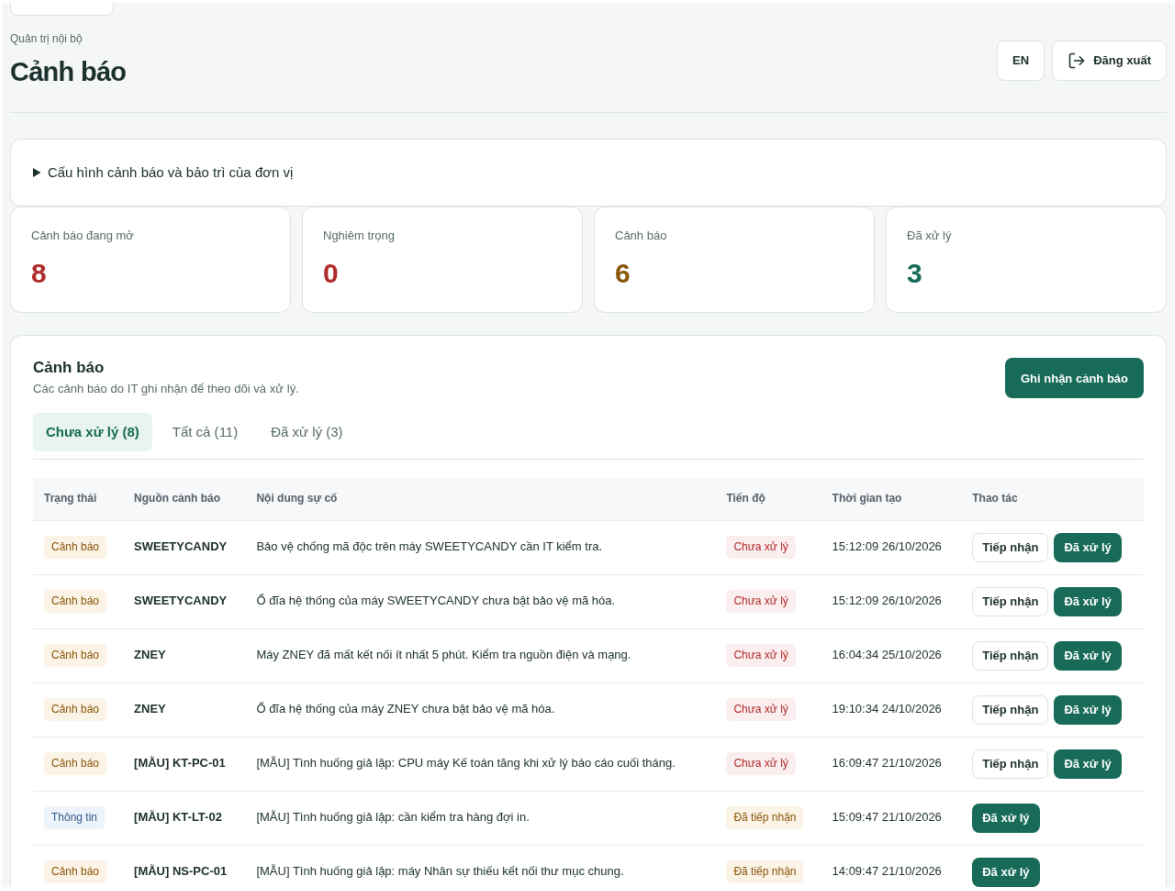
Nguồn: Hệ thống SentinelLAN.




Hình 4.17: Audit ghi nhận hoạt động bàn giao, hỗ trợ và lệnh

Nguồn: Hệ thống SentinelLAN.

Hai lần quan sát cuối ghi thời điểm heartbeat 15:51:56 và 15:53:32 (UTC+07) trên thiết bị SWEETYCANDY, Agent 1.0.4. Chênh lệch 96 giây giữa hai mốc được thấy trên UI cho biết có cập nhật mới; đây không phải phép đo chu kỳ gửi trung bình. Các cảnh báo chống mã độc hoặc mã hóa còn hiển thị được giữ để IT kiểm tra, không chuyển thành kết luận máy đã an toàn.




Hình 4.18: Cảnh báo thiết bị cần IT kiểm tra

Nguồn: Hệ thống SentinelLAN.

# CHƯƠNG 5. THẢO LUẬN KẾT QUẢ VÀ GIẢI PHÁP HOÀN THIỆN

## 5.1. Kết quả kiểm thử tự động

Hồ sơ kiểm chứng ngày 23/10/2026 ghi 382 ca .NET, gồm 380 ca đạt và hai ca bỏ qua. Hai ca bỏ qua thuộc kiểm tra rollback khi ghi audit thất bại và chia sẻ ngân sách giới hạn đăng nhập giữa các database scope. Bảng 5.1 giữ riêng trạng thái này để thể hiện phần chưa được xác nhận bởi lần chạy đó.

Bảng 5.1: Kết quả kiểm thử theo hồ sơ ngày 23/10/2026

| Bộ kiểm thử | Đạt | Bỏ qua | Diễn giải |
|---|---|---|---|
| Agent .NET | 94 | 0 | Theo kết quả TRX. |
| Application .NET | 65 | 0 | Theo kết quả TRX. |
| Architecture .NET | 12 | 0 | Theo kết quả TRX. |
| Domain .NET | 23 | 0 | Theo kết quả TRX. |
| Integration .NET | 186 | 2 | Chưa thể coi hai trường hợp bỏ qua là đạt. |
| Web UI | 127 | 0 | Các phép kiểm tra đạt; cổng độ phủ chưa đạt. |
| Mobile | 195 | 0 | Các phép kiểm tra đạt; cổng độ phủ chưa đạt. |
| Browser E2E | 13 | 0 | Theo tổng kết log cuối; không thay nghiệm thu native. |

Nguồn: Hồ sơ kiểm chứng ngày 23–24/10/2026, được lưu tại mốc 0c43c34.

Các bộ kiểm thử giao diện đạt các phép kiểm tra đã thiết kế, nhưng bước kiểm tra độ phủ còn thất bại. Web có độ phủ dòng 78,09%, nhánh 60,89% và hàm 66,17%. Mobile có độ phủ dòng 87,96%, nhánh 75,75% và hàm 75%. Ít nhất một chỉ tiêu của mỗi bộ thấp hơn ngưỡng cấu hình 80%.

Bảng 5.2: Độ phủ mã nguồn theo bộ đo

| Thành phần | Dòng | Nhánh | Hàm | Kết luận giới hạn |
|---|---|---|---|---|
| Khối mã .NET được đo kiểm | 81,31% | — | — | 6753/8305 dòng trong tập mã đo kiểm. |
| Web | 78,09% | 60,89% | 66,17% | Coverage command không đạt ngưỡng 80%. |

| Thành phần | Dòng | Nhánh | Hàm | Kết luận giới hạn |
|---|---|---|---|---|
| Mobile | 87,96% | 75,75% | 75,00% | Nhánh/hàm chưa đạt ngưỡng 80%. |

Nguồn: Bản tổng hợp độ phủ trong hồ sơ kiểm chứng của dự án; dấu — chỉ chỉ tiêu không được tổng hợp.

Độ phủ .NET 81,31% tương ứng 6.753/8.305 dòng trong tập mã được đo. Tỷ lệ này xác định mức mã đã đi qua theo bộ thu thập, không phải tỷ lệ chức năng đã nghiệm thu. Những nhánh adapter phụ thuộc Windows và dịch vụ ngoài cần bổ sung ca kiểm tra theo môi trường phù hợp.

## 5.2. Phép đo cục bộ và phục hồi HTTP

Theo hồ sơ ngày 24/10/2026, API và Agent chạy bằng hai tiến trình .NET riêng trên Windows, HTTP loopback và Development/InMemory. Sau heartbeat đầu tiên, phép đo kéo dài khoảng 300,2 giây; bộ chuyển tiếp trả HTTP 503 trong 180 giây. Cách bố trí này mô phỏng lỗi đường HTTP mà không sửa firewall hay ngắt card mạng.

Kết quả ghi 20 heartbeat thành công, 20 khóa idempotency khác nhau và 20 mẫu được API trả về; trong đó có năm mẫu mang thời điểm thu thập trước lúc phục hồi được gửi bù. Cơ chế chờ tăng dần khi lỗi làm khoảng lấy mẫu trong giai đoạn gián đoạn thay đổi. Vì vậy số mẫu gửi bù được tính từ dữ liệu quan sát, không suy ra từ chu kỳ danh nghĩa.

Bảng 5.3: Kết quả phép đo cục bộ đã lưu

| Chỉ tiêu | Kết quả và phạm vi |
|---|---|
| Môi trường | Windows; API và Agent riêng; HTTP loopback; Development/InMemory. |
| Gián đoạn mô phỏng | 180 giây; trả 503 tại bộ chuyển tiếp. |
| Mẫu gửi bù quan sát | 5 |
| Yêu cầu thành công / mẫu lưu | 20 / 20 |
| Working set Agent | 62,27–74,80 MiB |
| CPU Agent trung bình | 0,062% trên toàn bộ bộ xử lý logic |

| Chỉ tiêu | Kết quả và phạm vi |
|---|---|
| HTTP heartbeat trung vị | 3,46 ms; từ bộ chuyển tiếp đến API. |

Nguồn: Hồ sơ phép đo ngày 24/10/2026; Windows, HTTP loopback, InMemory.

Dữ liệu tài nguyên gồm 150 mẫu khoảng hai giây một lần; thống kê loại 30 giây đầu và chuẩn hóa CPU theo 12 bộ xử lý logic. Working set 62,27–74,80 MiB là bộ nhớ tiến trình Agent; CPU trung bình 0,062% là số đã chuẩn hóa. Trung vị HTTP 3,46 ms được đo từ bộ chuyển tiếp đến phản hồi API, chưa bao gồm toàn chuỗi từ tạo mẫu đến hiển thị trên web.

Phép đo bổ sung khả năng quan sát phục hồi và tài nguyên trong một lần chạy ngắn. Để xây dựng chỉ tiêu vận hành, cần lặp lại trên PostgreSQL và HTTPS, thử nhiều máy, gián đoạn mạng vật lý và tải nền được kiểm soát. Bộ hồ sơ hiện tại chưa đủ xác định SLA hoặc mức tải tối đa.

### 5.3. Kết quả nghiệm thu web trên bản triển khai

Chuỗi nghiệm thu ngày 26/10 đi qua cổng Admin, Employee, Agent và máy chủ đã triển khai. Sự thay đổi máy bàn giao xuất hiện ở cả hai vai trò; yêu cầu hỗ trợ có mã và ảnh do nhân viên chọn; IT tiếp nhận được phản ánh lại cho Employee. Đây là phần kết quả bổ sung cho các ảnh demo cục bộ trong hồ sơ cũ.

Bảng 5.4: Đối chiếu tình huống nghiệm thu và bằng chứng

| Mã | Kết quả ghi nhận | Bằng chứng |
|---|---|---|
| NT01 | Hai vai trò đăng nhập; xem đúng giao diện chức năng | W02, W11; thông tin đăng nhập không lưu trong gói. |
| NT02 | Kết thúc phân công cũ, giao SWEETYCANDY và xác minh hai phía | W07–W10, W36; operations.json. |
| NT03 | Tạo yêu cầu; gửi ảnh có đồng ý; Admin mở được ảnh | W12–W16, W38; mã yêu cầu và operations.json. |
| NT04 | Admin tiếp nhận; hai phía thấy InProgress và người phụ trách | W19–W20; yêu cầu chưa đóng. |
| NT05 | CollectTelemetryNow nhận biên lai Succeeded | W22, W32; mã lệnh và operations.json. |

| Mã | Kết quả ghi nhận | Bằng chứng |
|---|---|---|
| NT06 | Heartbeat tiếp tục cập nhật; API ready và image khớp commit | W25, W36, W40; heartbeat-observations.json, public-system-status.json. |

Nguồn: Phiên nghiệm thu và manifest 41 ảnh PNG ngày 26/10/2026.

Kết quả xác nhận hoạt động của quy trình chính trên một máy Windows đã kết nối. Trạng thái InProgress phản ánh đúng việc IT mới tiếp nhận, còn biên lai Succeeded thuộc riêng lệnh cập nhật thông số. Các tình huống thu hồi credential, mất mạng vật lý, cô lập và khôi phục trên OS chưa được thực hiện trong phiên web.

### 5.4. Thảo luận theo mục tiêu và câu hỏi nghiên cứu

Với câu hỏi thứ nhất, liên kết tổ chức–người dùng–thiết bị được thể hiện bằng việc bàn giao và tài nguyên Employee nhìn thấy sau thay đổi. Xung đột khi nhân viên còn giữ máy cũ cho thấy quy tắc một phân công đang hoạt động được áp dụng trong phiên nghiệm thu. Quy trình bàn giao cần thông báo rõ điều kiện này ngay trên form để người quản trị xử lý đúng.

Với câu hỏi thứ hai, HMAC, chữ ký lệnh và biên lai tạo các điểm kiểm tra riêng cho từng hướng trao đổi. API và Agent đã kết nối dù chuỗi phiên bản công bố khác nhau; trường tương thích thể hiện lựa chọn theo giao thức. Điều kiện cần duy trì là hợp đồng có thể đọc được, phương thức xác thực và khóa tin cậy còn phù hợp. Bằng chứng này áp dụng cho cặp phiên bản đã quan sát, chưa bao phủ mọi phiên bản lịch sử.

Với câu hỏi thứ ba, trạng thái yêu cầu và trạng thái lệnh được lưu tách biệt. IT tiếp nhận yêu cầu không làm máy tự trở thành đã xử lý; lệnh có biên lai không tự đóng yêu cầu của nhân viên. Cách biểu diễn này giúp người dùng phân biệt tiến độ công việc với kết quả kỹ thuật.

Với câu hỏi thứ tư, sản phẩm đáp ứng được luồng quản lý–hỗ trợ đã chọn và có dữ liệu truy vết từ bản triển khai. Độ phủ nhánh, trải nghiệm thông báo lỗi và nghiệm thu các hành động native còn hạn chế. Những phần này cần được ưu tiên theo rủi ro thay vì tăng số màn hình hoặc mở rộng chức năng trước khi hoàn thiện luồng hiện có.

Bảng 5.5: Mức đáp ứng mục tiêu của đồ án

| Mục tiêu | Kết quả hiện có | Phần cần hoàn thiện |
|---|---|---|
| Danh tính và bàn giao | Hợp đồng đăng ký; kiểm thử kế thừa; chuyển bàn giao thật qua web | Nghiệm thu đăng ký mới và thu hồi trên nhiều máy sạch. |
| Giám sát | Heartbeat thật, inventory và lệnh lấy số đo thành công | Đo độ trễ đầu cuối, vận hành dài hạn và dữ liệu thiếu. |
| Hỗ trợ nhân viên | Tạo yêu cầu, gửi ảnh và IT tiếp nhận ở hai vai trò | Hoàn tất vòng giải quyết–xác nhận–mở lại với người dùng. |
| Kiểm soát lệnh | Chữ ký/nonce/biên lai trong thiết kế và lệnh telemetry thật | Nghiệm thu từng adapter OS trên máy lab được phép. |
| Triển khai và truy vết | API ready; commit image khớp; audit và manifest ảnh | Phục hồi backup; triển khai nhiều thiết bị và đo tải. |

Nguồn: Đối chiếu hồ sơ kỹ thuật và kết quả nghiệm thu.

## 5.5. Các điểm giao diện cần cải thiện

Phiên nghiệm thu ghi nhận ba điểm ảnh hưởng cách người dùng hiểu trạng thái. Đây là quan sát trực tiếp trên giao diện, được giữ trong ảnh gốc để làm căn cứ đề xuất sửa. Chúng không làm mất các bản ghi thành công đã xác minh, nhưng tăng số bước kiểm tra và dễ khiến người dùng hiểu sai kết quả.

Bảng 5.6: Vấn đề quan sát được và giải pháp đề xuất

| Quan sát | Ảnh hưởng | Giải pháp |
|---|---|---|
| Thông báo khi gán máy trả 409 chưa nêu rõ nhân viên đang giữ máy khác | Admin khó nhận biết cần kết thúc phân công cũ | Hiển thị tên máy đang giữ; hướng dẫn chuyển bàn giao theo đúng quyền. |
| Chi tiết cấu hình hiện ManualSpecifications: null và Inventory: [object Object] | Dữ liệu nội bộ xuất hiện thay vì nội dung dễ đọc | Ánh xạ trường thành nhãn; dữ liệu thiếu hiển thị Chưa cập nhật. |
| Mục yêu cầu trên trang Máy tính của tôi chưa phản ánh yêu cầu mới ở Hỗ trợ IT | Employee có thể tưởng yêu cầu chưa tạo | Thống nhất nguồn dữ liệu hoặc phân biệt rõ loại yêu cầu; liên kết sang chi tiết. |

Nguồn: Quan sát trong phiên nghiệm thu, mô tả tại danh mục ảnh và ảnh gốc 26/10/2026.

Các cảnh báo bảo vệ trên SWEETYCANDY cần được IT xác minh theo khả năng đọc của Agent và cấu hình Windows. Giao diện nên cung cấp thời điểm quan sát, nguyên nhân thiếu dữ liệu và bước kiểm tra tiếp theo. Nhãn Unknown cần được phân biệt với đã phát hiện nguy cơ hoặc đã khắc phục.

### 5.6. Giải pháp hoàn thiện vận hành

Trước khi mở rộng, ưu tiên bổ sung kiểm thử cho các nhánh sai quyền, xung đột bàn giao và trạng thái hỗ trợ. Mỗi lỗi giao diện ở Bảng 5.6 cần có ca hồi quy theo hành vi mong đợi. Độ phủ được theo dõi trên cùng tập mã và cấu hình để đánh giá tiến bộ, đồng thời kiểm tra nguyên nhân của hai ca .NET bị bỏ qua.

Phát hành cần gắn mã nguồn, image và bộ cài Agent với thông tin phiên bản có thể đối chiếu. Triển khai mới giữ khóa và cấu hình cần thiết, kiểm tra readiness, hợp đồng tương thích, heartbeat và một lệnh ít tác động trước khi mở cho người dùng. Quy trình rollback và khôi phục database được thử ở môi trường tách biệt với khóa mã hóa tương ứng.

Nghiệm thu mở rộng cần nhiều thiết bị Windows và mạng khác nhau, có cả reboot và gián đoạn vật lý. Mobile được đánh giá bằng bản build trên thiết bị thực, ghi rõ phiên bản iOS/Android, quyền camera và trạng thái thông báo. Các hành động ảnh hưởng hệ điều hành chỉ thử trên máy lab với kế hoạch phục hồi được xác nhận trước.

# CHƯƠNG 6. KẾT LUẬN, HẠN CHẾ VÀ HƯỚNG PHÁT TRIỂN

## 6.1. Kết luận

Đồ án đã xây dựng SentinelLAN theo quy trình liên kết thiết bị, người sử dụng và công việc hỗ trợ. Backend phân lớp, PostgreSQL, cổng web và Agent phối hợp để duy trì danh tính máy, cập nhật dữ liệu kỹ thuật, kiểm soát quyền và ghi nhận kết quả lệnh. Phần thiết kế phân biệt khóa xác thực Agent với khóa ký lệnh, đồng thời giữ trạng thái chưa xác nhận khi thiếu biên lai.

Kết quả triển khai ngày 26/10/2026 xác nhận bàn giao SWEETYCANDY cho Employee, tạo yêu cầu hỗ trợ có ảnh và sự đồng ý, IT tiếp nhận và cập nhật thông số qua lệnh thành công. Agent 1.0.4 gửi heartbeat mới; API báo ready và có commit đối chiếu với image đang chạy. Các kết quả này trả lời mục tiêu xây dựng một quy trình quản lý–hỗ trợ có thể theo dõi trên hệ thống.

Giá trị của đồ án là sản phẩm đã triển khai cùng cách lưu trạng thái và bằng chứng phù hợp từng thao tác. Hệ thống hỗ trợ người vận hành xác định máy, người sử dụng và tiến độ xử lý từ cùng ngữ cảnh nghiệp vụ; đánh giá hiệu quả kinh tế cần được bổ sung khi sử dụng tại một tổ chức thực tế.

## 6.2. Hạn chế

Nghiệm thu triển khai mới quan sát một thiết bị Windows và một luồng yêu cầu chưa đóng. Chưa có thử nghiệm tải nhiều thiết bị, đánh giá độ ổn định dài hạn hoặc khảo sát trải nghiệm người dùng tại doanh nghiệp. Phép đo tài nguyên là dữ liệu cục bộ trong thời gian ngắn, không đại diện cho toàn bộ môi trường vận hành.

Hồ sơ tự động còn hai ca .NET bỏ qua và một số chỉ tiêu độ phủ web/mobile dưới ngưỡng. Các thao tác cài đặt, khóa, cô lập, bảo trì đặc quyền và khôi phục thực tế cần nghiệm thu riêng trên máy lab. Bản báo cáo chưa bổ sung ảnh và kết quả mobile native.

Kiểm soát audit ở lớp ứng dụng chưa bao phủ quyền quản trị trực tiếp cơ sở dữ liệu. Quản lý khóa, phục hồi dữ liệu mã hóa và luân chuyển khóa giữa Agent–

máy chủ cần quy trình vận hành cùng các lần diễn tập. Một số lỗi diễn đạt và ánh xạ dữ liệu trên giao diện vẫn cần sửa.

### 6.3. Hướng phát triển

Giai đoạn tiếp theo tập trung hoàn thiện quy trình hỗ trợ từ tiếp nhận đến xác nhận giải quyết, sửa các vấn đề giao diện đã ghi nhận và bổ sung kiểm thử hồi quy. Tập kiểm thử được mở rộng theo nhánh rủi ro, đặc biệt với bàn giao, tải ảnh, quyền theo tổ chức và các trường hợp lệnh chưa xác nhận.

Môi trường nghiệm thu được mở rộng sang nhiều máy và điều kiện mạng, kiểm tra khởi động lại, mất kết nối vật lý, phục hồi backup và khả năng nâng cấp tương thích. Mỗi lần chạy giữ phiên bản, cấu hình và dữ liệu thô để so sánh. Trên mobile, ưu tiên xác nhận đăng nhập, máy được giao, hỗ trợ và đọc QR trên thiết bị thực trước các chức năng bổ sung.

Khi có dữ liệu sử dụng tại tổ chức, có thể đánh giá thời gian từ tạo yêu cầu đến tiếp nhận, thời gian giải quyết và mức đầy đủ của hồ sơ thiết bị. Các chỉ tiêu này giúp xác định tác động thực tế của SentinelLAN và định hướng phát triển tiếp theo.

# TÀI LIỆU THAM KHẢO


Tài liệu tiếng Việt

Đại học Kinh tế Thành phố Hồ Chí Minh, 2025. *Hướng dẫn thực hiện luận văn thạc sĩ*. Mã hiệu ĐTSĐH.HDLV; chỉnh sửa 19/5/2025, mục I.5–I.6 về trích dẫn và danh mục tài liệu tham khảo. [Trực tuyến] Có tại: https://sdh.ueh.edu.vn/ckfinder/files/20250519_HUONG%20DAN%20THUC%20HIEN%20LUAN%20VAN%20THAC%20SI%20DUA%20LEN%20WEB%20BAN%20DAO%20TAO%202024%281%29.pdf [Truy cập ngày 26/10/2026].

Tài liệu tiếng nước ngoài

Dworkin, M., 2007. *Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC*. NIST Special Publication 800-38D. Gaithersburg, MD: National Institute of Standards and Technology. Có tại: https://doi.org/10.6028/NIST.SP.800-38D [Truy cập ngày 26/10/2026].

Krawczyk, H., Bellare, M. and Canetti, R., 1997. *HMAC: Keyed-Hashing for Message Authentication*. RFC 2104. Có tại: https://www.rfc-editor.org/info/rfc2104 [Truy cập ngày 26/10/2026].

ManageEngine, n.d. *Unified Endpoint Management Solution from ManageEngine Endpoint Central*. [Trực tuyến] Có tại: https://www.manageengine.com/products/desktop-central/endpoint-management.html [Truy cập ngày 26/10/2026].

Martin, R.C., 2017. *Clean Architecture: A Craftsman's Guide to Software Structure and Design*. 1st ed. Boston, MA: Pearson. ISBN 9780134494326. Có tại: https://www.pearson.com/en-us/subject-catalog/p/clean-architecture-a-craftsmans-guide-to-software-structure-and-design/P200000009528 [Truy cập ngày 26/10/2026].

Microsoft, 2026. *Overview of ASP.NET Core SignalR*. ASP.NET Core 10.0. [Trực tuyến] Có tại: https://learn.microsoft.com/en-us/aspnet/core/signalr/introduction?view=aspnetcore-10.0 [Truy cập ngày 26/10/2026].

Moriarty, K., Kaliski, B., Jonsson, J. and Rusch, A., 2016. *PKCS #1: RSA Cryptography Specifications Version 2.2*. RFC 8017. Có tại: https://www.rfc-editor.org/info/rfc8017 [Truy cập ngày 26/10/2026].

Moriarty, K., Kaliski, B. and Rusch, A., 2017. *PKCS #5: Password-Based Cryptography Specification Version 2.1*. RFC 8018. Có tại: https://www.rfc-editor.org/info/rfc8018 [Truy cập ngày 26/10/2026].

osquery, n.d. *Everything in SQL*. Tài liệu dự án. [Trực tuyến] Có tại: https://osquery.readthedocs.io/en/stable/introduction/sql/ [Truy cập ngày 26/10/2026].

OWASP Foundation, 2025. *Application Security Verification Standard*. Version 5.0.0. [Tiêu chuẩn trực tuyến] Có tại: https://asvs.owasp.org/ [Truy cập ngày 26/10/2026].

Peffers, K., Tuunanen, T., Rothenberger, M.A. and Chatterjee, S., 2007. 'A Design Science Research Methodology for Information Systems Research'. *Journal of Management Information Systems*, 24(3), trang 45–77. DOI: 10.2753/MIS0742-1222240302. Có tại: https://www.jmis-web.org/articles/765 [Truy cập ngày 26/10/2026].

PostgreSQL Global Development Group, n.d. *PostgreSQL 18 Documentation: 5.5. Constraints*. [Trực tuyến] Có tại: https://www.postgresql.org/docs/18/ddl-constraints.html [Truy cập ngày 26/10/2026].

Rose, S., Borchert, O., Mitchell, S. and Connelly, S., 2020. *Zero Trust Architecture*. NIST Special Publication 800-207. Gaithersburg, MD: National Institute of Standards and Technology. Có tại: https://doi.org/10.6028/NIST.SP.800-207 [Truy cập ngày 26/10/2026].

Teclib, n.d. *Discover GLPI features*. [Trực tuyến] Có tại: https://www.glpi-project.org/en/features/ [Truy cập ngày 26/10/2026].

Wazuh, n.d. *Components: Getting started with Wazuh*. Tài liệu dự án. [Trực tuyến] Có tại: https://documentation.wazuh.com/current/getting-started/components/index.html [Truy cập ngày 26/10/2026].